

分析题

- 一、最高概率题型：加密模式 / IV / nonce / 完整性 / 重放综合分析
 - 可能题干形式
 - 参考答案：AES-CTR + COUNT 重启归零 + 无 MAC
 - 参考答案：AES-GCM + nonce 计数器回滚
 - 参考答案：上行/下行同密钥 + 同计数器
 - 答题核心
 - 1. 机密性问题
 - 2. 完整性问题
 - 3. 重放问题
 - 4. 密钥管理问题
 - 5. 推荐改进方案
 - 这类题的标准答题模板
- 二、很可能：LTE / 5G 密钥层次、切换安全、前向/后向安全分析
 - 先把这些 LTE 密钥名说成人话
 - 1. K_ASME 是什么？
 - 2. K_NASenc / K_NASint 是什么？
 - 3. K_eNB 是什么？
 - 4. K_RRCenc / K_RRCint / K_UPenc 是什么？
 - 5. NH / NCC 是什么？
 - 6. 这些名词在题里怎么用来抓漏洞？
 - 可能题干形式
 - 参考答案：旧 eNodeB 直接把 K_eNB 给目标 eNodeB
 - 参考答案：为了低时延让源基站交密钥
 - 参考答案：5G 中 NAS、RRC、用户面共用同一密钥
 - 答题核心
 - 1. 为什么要分层密钥？
 - 2. 旧基站把密钥直接给新基站有什么问题？
 - 3. NH/NCC 的作用
 - 4. 5G 可怎么增强？
 - 这类题的标准模板
- 三、很可能：WLAN / WEP / WPA / WPA2 / WPA3 方案分析
 - 可能题干形式

- 参考答案：校园 WLAN 使用 RC4 + 24 bit IV + CRC32
- 参考答案：企业 WLAN 使用 WPA2-PSK 且全员共享密码
- 参考答案：WPA2 四次握手不检查重放计数器
- WEP 重点答题点
 - 1. 认证弱
 - 2. IV 太短
 - 3. RC4 密钥调度弱点
 - 4. CRC32 不能防篡改
 - 5. 密钥管理差
- 改进方案
- 如果考 WPA2 四次握手
- 四、较可能：5G 身份隐私、SUPI/SUCI、5G-AKA、漫游安全分析
 - 可能题干形式
 - 参考答案：SUCI 在漫游中的作用和局限
 - 参考答案：5G 有 SUCI 但允许回落到 4G/2G
 - 参考答案：5G SBA 架构中的 API 安全
 - 答题核心
 - 1. SUPI / SUCI
 - 2. SUCI 的局限
 - 3. 5G-AKA
 - 4. 漫游安全 SEPP
 - 5. SBA 安全
 - 高分总结句
- 五、较可能：TETRA 空口加密、传输加密、端到端加密综合分析
 - 可能题干形式
 - 参考答案：TETRA 只做空口加密，不做端到端加密
 - 参考答案：TETRA 群组通信中调度监听与内容保护的取舍
 - 参考答案：TETRA 端到端加密的密钥流同步与迟到加入
 - 答题核心
 - 1. 空口加密
 - 2. 传输加密
 - 3. 端到端加密 E2EE
 - 4. TETRA 和 GSM 对比
 - 高分总结句
- 六、可能：给一个新无线系统，让你做威胁建模和安全体系设计

- 可能题干形式
 - 参考答案：校园无线物联网系统威胁建模与安全设计
 - 参考答案：应急调度专用无线通信系统安全分析
- 答题框架
 - 1. 先分安全域
 - 2. 再列威胁
 - 3. 对应安全服务
 - 4. 给出机制设计
- 高分总结句
- 七、可能：认证协议 / 重放 / 中间人 / 新鲜性分析
 - 可能题干形式
 - 参考答案：共享密钥挑战响应协议分析
 - 参考答案：未认证 Diffie-Hellman 的中间人攻击
 - 参考答案：时间戳防重放但终端不同步
 - 常见漏洞
 - 1. 单向认证
 - 2. 缺少新鲜性
 - 3. MITM
 - 4. 反射攻击
 - 5. 未绑定身份和密钥
 - 高分总结句
- 八、可能：用户面完整性保护与“只加密不认证”分析
 - 参考答案：用户面只加密不做完整性保护
 - 答题要点
 - 改进方案
- 九、可能：漫游安全 / SEPP / SS7 / Diameter / 边界保护
 - 可能题干形式
 - 参考答案：5G 漫游中过度信任拜访网络与 SEPP
 - 答题要点
- 十、最后一道最可能的“综合题套路”
 - 对这个综合题套路的参考答案
- 十一、最后分析题通用答题模板
 - 第一步：说明安全目标
 - 第二步：找攻击者能力
 - 第三步：逐项分析方案问题

- 第四步：提出改进
- 第五步：总结取舍
- 十二、最建议最后重点背的三套答案
 - 1. “密码模式分析题”模板
 - 2. “LTE/5G 密钥体系分析题”模板
 - 3. “WLAN/WEW/WPA 分析题”模板
- 十三、最终押题判断
- 附录一：不会分析时怎么拆题
 - 1. 看到“加密算法很强”，不要马上认为安全
- 附录二：各种加密模式到底怎么分析
 - 1. ECB：看到就直接判不安全
 - 2. CBC：重点看 IV、填充、完整性
 - (1) IV 是否随机、不可预测、每次不同
 - (2) CBC 不自带完整性
 - (3) 小心 padding oracle
 - 3. CTR：重点看 nonce/counter 绝对不能重复
 - 4. OFB：和 CTR 一样按“流密码”分析
 - 5. CFB：也要关注 IV，但错误传播和 CTR/OFB 略不同
 - 6. GCM：重点看 nonce 唯一 + 自带认证
 - 7. CCM：CTR 加密 + CBC-MAC 认证
 - 8. GCM 和 CCM 怎么区分答？
- 附录三：IV、nonce、counter 到底怎么看
 - 1. 看到这些话，就要怀疑重复
 - 2. IV 是否可以公开？
 - 3. “随机 IV”和“计数器 nonce”哪个好？
- 附录四：完整性问题到底怎么看
 - 1. 什么叫“只加密不认证”
 - 2. 为什么只加密不够？
 - 3. CRC 为什么不算完整性保护？
 - 4. MAC 和数字签名有什么区别？
- 附录五：重放问题到底怎么看
 - 1. 什么是重放？
 - 2. 看到什么就判断有重放风险？
 - 3. 加密能防重放吗？
 - 4. 防重放机制怎么写？

- 附录六：前向安全、后向安全到底怎么判断
 - 1. 先把两个概念说成人话
 - 前向安全 Forward Security
 - 后向安全 Backward Security
 - 2. 用一句口诀记
 - 3. 怎么判断有没有前向安全？
 - 4. 怎么判断有没有后向安全？
 - 5. LTE 切换里怎么判断？
 - 情况 A：旧 eNodeB 直接把 K_{eNB} 发给新 eNodeB
 - 情况 B：横向派生
 - 情况 C：纵向派生 / NH/NCC
 - 6. 什么时候说“没有前向安全”？
 - 7. 什么时候说“没有后向安全”？
 - 8. 群组通信里的前向/后向安全
- 附录七：密钥分离到底怎么分析
 - 1. 看到“所有业务共用一个密钥”，直接写问题
 - 2. 为什么要分离？
 - 3. LTE/5G 里怎么套
 - 4. WLAN 里怎么套
- 附录八：身份隐私题怎么分析
 - 1. 看到永久身份明文发送，就写隐私泄露
 - 2. TMSI/GUTI/SUCI 分别解决什么
 - 3. 临时身份不等于完全匿名
- 附录九：WLAN 题怎么从题干抓漏洞
 - 1. 看到 WEP，直接抓五个点
 - 2. 看到 WPA2-PSK 全员共享密码
 - 3. 看到四次握手
- 附录十：TETRA 题怎么分析
 - 1. 先判断保护范围
 - 2. 群组通信一定要想到密钥管理
 - 3. 端到端加密为什么还需要同步？
- 附录十一：5G/SUPI/SUCI/SEPP/SBA 题怎么分析
 - 1. SUPI/SUCI 题
 - 2. 5G-AKA 题
 - 3. SEPP 题

- 4. SBA 题
- 附录十二：分析题万能“定位问题”表
- 附录十三：真正考试时的“笨办法答题流程”
 - 第 1 句：先评价总体
 - 第 2 句：说机密性
 - 第 3 句：说完整性
 - 第 4 句：说重放
 - 第 5 句：说密钥
 - 第 6 句：说改进

一、最高概率题型：加密模式 / IV / nonce / 完整性 / 重放综合分析

可能性：★★★★★

去年最后一道已经是 AES-CBC 方案分析，所以今年很可能换一个模式或换一个场景继续考：

- AES-CTR
- AES-GCM
- AES-CCM
- OFB / CFB
- 流密码
- LTE/5G 中的 COUNT / BEARER / DIRECTION 参数
- WPA2-CCMP / WPA3-GCMP
- “只加密不认证”
- “同一个密钥长期使用”
- “IV/nonce 重复或可预测”
- “通信双方预共享密钥但没有密钥更新”

可能题干形式

例如：

某无线通信系统使用 AES-CTR 加密用户数据。双方预先共享密钥 K，每个数据包使用计数器 COUNT 作为输入，但系统重启后 COUNT 从 0 开始。未使用 MAC 或完整性校验。请分析该方案的安全问题并提出改进建议。

参考答案：AES-CTR + COUNT 重启归零 + 无 MAC

这题先抓三个关键词：**AES-CTR、COUNT 重启从 0 开始、未使用 MAC。**

1. 机密性问题：COUNT 回滚会导致密钥流重复

- CTR 模式不是直接“用 AES 加密明文”，而是用 AES 根据 $K + \text{nonce/counter}$ 生成密钥流，再和明文异或。
- 如果系统重启后 COUNT 又从 0 开始，那么同一密钥 K 下可能再次出现相同 COUNT，于是生成相同密钥流。
- 攻击者如果获得两个密文：

$$C_1 = P_1 \oplus S$$

$$C_2 = P_2 \oplus S$$

则：

$$C_1 \oplus C_2 = P_1 \oplus P_2$$

- 如果攻击者知道其中一个明文，就可以恢复另一个明文。

2. 完整性问题：CTR 不自带防篡改

- CTR 是流密码式加密，攻击者翻转密文某一位，会导致解密后明文对应位也翻转。
- 因为没有 MAC，接收方无法发现密文被恶意修改。
- 所以该方案不仅可能泄露明文关系，还容易受到比特翻转攻击。

3. 重放问题：题干没有说序列号或滑动窗口

- 攻击者可以记录旧密文，之后重新发送。
- 接收方如果只解密，不检查序列号或窗口，就无法判断消息是不是旧消息。

4. 密钥管理问题：预共享密钥长期使用风险大

- 如果 K 长期不变，一旦 COUNT 重复，风险会不断累积。
- 如果密钥泄露，历史通信和未来通信都可能受影响。

5. 改进方案

- COUNT 必须持久化保存，设备重启后不能回滚。
- nonce/counter 中加入设备 ID、会话号、方向标识 DIRECTION、承载标识 BEARER。
- 加入 MAC/HMAC/CMAC，或者直接使用 AES-GCM/AES-CCM 这类 AEAD 模式。
- 加入序列号和滑动窗口防重放。
- 使用 KDF 派生不同方向、不同用途的密钥，并定期更新密钥。

一句话版：

AES-CTR 最怕同一密钥下 counter 重复。COUNT 重启归零会导致密钥流复用，泄露明文关系；没有 MAC 又会导致密文可被篡改；还需要序列号防重放。应保证 COUNT 持久唯一，加入方向/承载标识，使用 AEAD 或 MAC，并进行密钥分离和更新。

或者：

某系统采用 AES-GCM 保护无线链路数据，nonce 由设备编号和本地计数器组成。设备掉电后计数器可能回滚。请分析风险。

参考答案：AES-GCM + nonce 计数器回滚

这题先抓两个关键词：**AES-GCM**、**计数器可能回滚**。

1. 先肯定 GCM 正常情况下是好东西

- AES-GCM 是 AEAD 模式，正常使用时同时提供机密性和完整性。
- 它会输出密文和认证标签 tag，接收方验证 tag 后才能接受消息。

2. 核心风险：GCM 极度依赖 nonce 唯一性

- GCM 底层使用 CTR 方式加密，所以同一密钥下 nonce 不能重复。
- 题干说 nonce = 设备编号 + 本地计数器，看似合理；但如果设备掉电后计数器回滚，就可能再次使用旧 nonce。
- 一旦同一密钥 K 下 nonce 重复，CTR 密钥流会重复，攻击者可以通过密文异或得到明文异或关系。

3. GCM 的 nonce 重复比普通 CTR 更严重

- CTR 中 nonce 重复主要破坏机密性。
- GCM 中 nonce 重复还可能破坏认证安全，使攻击者有机会伪造认证标签 tag。
- 所以 GCM 的 nonce 唯一性要求比“普通随机数不重复”更严格。

4. 重放和状态回滚问题

- 计数器回滚还意味着接收方可能无法区分新包和旧包。
- 攻击者可能重放旧密文，若系统没有重放窗口，就可能被接受。

5. 改进方案

- 计数器必须写入安全非易失存储，掉电后不能回滚。
- 每次重新启动或重新认证时派生新会话密钥，避免旧 nonce 空间重复使用。
- nonce 中可以加入随机会话号、方向标识、承载标识和递增序列号。
- 当计数器接近上限时必须换密钥。
- tag 验证失败必须丢弃消息，不能继续处理明文。

一句话版：

AES-GCM 本身是安全的 AEAD，但前提是同一密钥下 nonce 绝不重复。掉电导致计数器回滚会造成 nonce 重复，进而导致密钥流复用、明文关系泄露，甚至可能破坏认证标签安全。应持久化计数器、重启后重协商密钥，并加入防重放机制。

或者：

某移动通信系统上行和下行都使用同一个密钥和相同计数器生成密钥流，请分析可能攻击及改进方案。

参考答案：上行/下行同密钥 + 同计数器

这题先抓关键词：**上行和下行共用密钥、相同计数器、生成密钥流**。

1. 核心问题：跨方向密钥流重复

- 上行和下行如果使用同一个 K，又使用相同计数器，就会生成相同密钥流。
- 假设上行密文为：

$$C_{up} = P_{up} \oplus S$$

下行密文为：

$$C_{down} = P_{down} \oplus S$$

则：

$$C_{up} \oplus C_{down} = P_{up} \oplus P_{down}$$

- 攻击者可以得到上下行明文之间的关系；若知道一个方向的明文格式，就可能推测另一个方向内容。

2. 可能出现反射或跨方向重放

- 如果协议没有区分上行/下行，攻击者可能把一个方向的消息拿到另一个方向重放。
- 接收方如果不检查方向标识，可能误把上行消息当下行消息处理，或反过来。

3. 说明密钥分离不足

- 上行、下行是不同方向，应该使用不同密钥或至少在密钥流输入中加入方向标识。
- 如果同一密钥同时用于多个方向，会扩大单个密钥泄露的影响范围。

4. 改进方案

- 使用 KDF 从主密钥派生上行密钥和下行密钥。
- 即使使用同一个根密钥，也要在密钥流输入中加入 DIRECTION 字段。
- 参考 LTE/5G：使用 `COUNT + BEARER + DIRECTION` 共同作为算法输入，避免跨包、跨承载、跨方向重复。
- 加入 MAC/AEAD tag，防止跨方向篡改和重放。
- 加入序列号和滑动窗口。

一句话版：

上下行共用密钥和计数器会导致同一密钥流在两个方向重复使用，攻击者可通过上下行密文异或得到明文关系，还可能进行跨方向重放。应进行上下行密钥分离，或至少加入 DIRECTION、BEARER、COUNT 等上下文参数，并加入完整性和防重放保护。

答题核心

1. 机密性问题

如果是 CTR/OFB/流密码类：

- 同一密钥下不能重复密钥流；
- 如果相同 K 和相同 nonce/counter 被重复使用，则：

$$C_1 = P_1 \oplus S$$

$$C_2 = P_2 \oplus S$$

所以：

$$C_1 \oplus C_2 = P_1 \oplus P_2$$

攻击者可以通过两个密文异或获得两个明文之间的关系，若知道一个明文，可恢复另一个明文。

如果是 GCM：

- nonce 重复不仅破坏机密性，还可能破坏认证完整性；
- GCM 对 nonce 唯一性要求极高。

2. 完整性问题

如果系统“只加密不认证”，一定要写：

- 加密不等于完整性保护；
- 攻击者可能修改密文，导致解密后明文被可控改变；
- CTR/流密码尤其容易被比特翻转攻击；
- CBC 也有可塑性，可能被利用进行比特翻转或 padding oracle 类攻击；
- CRC 不能替代 MAC，因为 CRC 是线性检错码，不具备抗恶意篡改能力。

3. 重放问题

如果题干没有序列号、时间戳、随机数或滑动窗口，要写：

- 攻击者可以重放旧密文；
- 接收方无法判断消息是否为新鲜消息；
- 对控制信令尤其危险，例如重放接入请求、断开请求、切换命令、授权命令等。

4. 密钥管理问题

常见问题：

- 长期使用同一个通信密钥；
- 上行、下行、信令、用户面共用同一个密钥；
- 不同业务或不同会话共用密钥；
- 没有密钥更新机制；
- 没有密钥派生和密钥分离；
- 没有前向安全和后向安全。

改进：

- 使用 KDF 从主密钥派生不同用途密钥；
- 上行/下行分离；
- 加密密钥和完整性密钥分离；
- NAS / AS / RRC / UP 分离；
- 定期更新密钥；
- 重新认证或切换时派生新密钥；
- 必要时引入 Diffie-Hellman 实现前向安全。

5. 推荐改进方案

高分答案可以这样写：

- 使用 AEAD 模式，例如 AES-GCM 或 AES-CCM；
- 每个包使用全局唯一 nonce；
- nonce 可以由方向标识、承载标识、序列号、随机数共同组成；
- 参考 LTE/5G：COUNT、BEARER、DIRECTION 等上下文参数防止同一密钥流跨方向、跨承载重复；
- 加入完整性保护，例如 HMAC、CMAC、GMAC 或 AEAD tag；
- 加入重放保护，例如递增序列号、时间戳、随机挑战、滑动窗口；
- 使用 KDF 派生不同密钥；
- 定期重协商或更新密钥；
- 关键控制信令必须强完整性保护；
- 密钥和计数器状态需要安全存储，防止掉电回滚导致 nonce 重复。

这类题的标准答题模板

该方案不能只看是否使用了强密码算法，还要看 IV/nonce 是否唯一、是否有完整性保护、是否防重放、是否进行密钥分离和密钥更新。

如果 IV/nonce 重复，会导致密钥流重复，泄露明文关系；如果没有 MAC/AEAD，攻击者可以篡改密文；如果没有序列号或时间戳，攻击者可以重放旧消息；如果长期共用一个密

钥，会扩大密钥泄露影响。

改进方案是采用 AEAD，如 AES-GCM/CCM，保证 nonce 唯一，加入序列号和重放窗口，用 KDF 派生上行/下行、加密/完整性、信令/用户面不同密钥，并设计密钥更新机制。

二、很可能：LTE / 5G 密钥层次、切换安全、前向/后向安全分析

可能性：★★★★☆

去年第 7 题已经考了 LTE 密钥管理能否实现前向安全和后向安全，是 15 分简答。这个方向很适合升级成 20 分分析题。

尤其资料里 LTE 和 5G 的整理都很强调：

- K_ASME
- K_NASenc / K_NASint
- K_eNB
- K_RRCenc / K_RRCint / K_UPenc
- NH / NCC
- 横向派生
- 纵向派生
- X2 / S1 切换
- eNodeB / gNodeB 不完全可信
- NAS 安全和 AS 安全分层
- 5G 中 K_SEAF、K_AMF、K_gNB、K_RRC、K_UP

先把这些 LTE 密钥名说成人话

你不用一开始就把它们当公式背。先把 LTE 密钥体系想成一棵树：

核心网先和手机认证，得到一个“大根密钥” K_ASME；然后从 K_ASME 往下派生 NAS 密钥、基站密钥 K_eNB；基站密钥再派生 RRC 和用户面密钥；切换时用 NH/NCC 帮助生成下一跳基站密钥。

也就是大致这样：

USIM/核心网长期密钥

↓ EPS-AKA 认证

K_ASME

← LTE 安全上下文的“大根密钥”

↓

├ K_NASenc

← NAS 信令加密密钥，保护 UE ↔ MME 控制信令的保密性

├ K_NASint

← NAS 信令完整性密钥，保护 UE ↔ MME 控制信令不被篡改

├ K_eNB

← 基站侧密钥，交给 eNodeB，用来派生无线接入层密钥

|

↓

		K_RRCenc	← RRC 信令加密密钥，保护 UE ↔ eNodeB 的无线控制信令保密性
		K_RRCint	← RRC 信令完整性密钥，保护 UE ↔ eNodeB 的无线控制信令完整性
		K_UPenc	← 用户面加密密钥，保护用户数据，如上网流量的空口加密
		NH / NCC	← 切换时用来生成后续基站密钥，避免旧基站一直知道新基站密钥

下面逐个解释。

1. K_ASME 是什么？

K_ASME 可以理解成：

LTE 认证成功后得到的“总安全上下文密钥”或“上层锚点密钥”。

它不是直接拿来加密所有数据的，而是用来继续派生别的密钥。

它从哪里来？

- UE 和核心网通过 EPS-AKA 完成认证；
- 认证过程中会产生 CK、IK 等材料；
- 再结合服务网络标识等参数，通过 KDF 派生出 K_ASME。

它有什么用？

- 派生 NAS 层密钥；
- 派生基站密钥 K_eNB；
- 作为 LTE 后续安全上下文的根。

考试怎么写：

K_ASME 是 LTE EPS-AKA 后形成的核心安全上下文密钥，相当于后续 NAS 安全和 AS 安全的锚点。它不应直接用于所有加密，而应通过 KDF 派生不同用途的子密钥，以实现密钥分离。

如果题干说“所有通信都直接用 K_ASME 加密”，就写问题：

- 密钥分离不足；
- K_ASME 泄露会影响 NAS、AS、用户面全部安全；
- 基站不应获得过高层级的核心密钥；
- 应派生 K_NASenc、K_NASint、K_eNB 等不同密钥。

2. K_NASenc / K_NASint 是什么？

先理解 NAS：

NAS 是 UE 和核心网 MME 之间的非接入层信令。

它不是普通用户上网数据，而是控制消息，例如：

- 注册 / 附着；
- 鉴权；
- 移动性管理；
- 会话管理；
- 安全模式命令。

K_NASenc:

NAS encryption key, NAS 加密密钥。

用来保护 UE ↔ MME 的 NAS 信令机密性，防止被 eNodeB 或空口攻击者看懂。

K_NASint:

NAS integrity key, NAS 完整性密钥。

用来保护 UE ↔ MME 的 NAS 信令完整性，防止被篡改、伪造、插入。

为什么要分成 enc 和 int?

因为：

- 加密解决“别人看不看得懂”；
- 完整性解决“别人能不能改，改了能不能发现”；
- 两个安全目标不同，所以密钥也要分开。

考试怎么写：

K_NASenc 用于 NAS 信令加密，K_NASint 用于 NAS 信令完整性保护。二者分离体现了加密和完整性密钥分离原则，避免同一密钥同时承担不同密码学用途。

如果题干说“NAS 只加密不做完整性”，就写：

- NAS 是核心控制信令，只加密不够；
- 攻击者可能篡改安全模式命令、注册、会话控制等消息；
- 必须用 K_NASint 计算 NAS-MAC 验证完整性。

3. K_eNB 是什么？

K_eNB 可以理解成：

MME 派生并交给 eNodeB 的基站密钥。

它的作用是让基站能保护 UE 和 eNodeB 之间的无线接入层通信。

注意：

- K_eNB 不是长期根密钥；
- eNodeB 不应该拿到 K_ASME；
- eNodeB 拿到的是低一层的 K_eNB；
- 再由 K_eNB 派生 RRC 和用户面密钥。

考试怎么写：

K_eNB 是由 K_ASME 派生出的接入层基站密钥，用于 eNodeB 侧的 AS 安全。它使 eNodeB 能保护 UE 与基站之间的 RRC 信令和用户面数据，但又避免基站获得核心网层面的 K_ASME。

如果题干说“旧 eNodeB 把 K_eNB 直接发给新 eNodeB”，就写：

- 旧基站知道新基站后续通信密钥；
- 旧基站被攻破会影响切换后的通信；
- 后向安全差；
- 缺少密钥隔离；
- 应使用 NH/NCC 或由 MME 参与派生新 K_eNB。

4. K_RRCenc / K_RRCint / K_UPenc 是什么？

先理解 AS：

AS 是 UE 和 eNodeB 之间的接入层安全。

AS 里又分两类东西：

1. RRC 信令：控制无线连接的信令；
2. UP 用户面：真正的用户数据，例如上网数据。

K_RRCenc：

RRC 加密密钥。

用来加密 UE ↔ eNodeB 之间的 RRC 控制信令。

K_RRCint：

RRC 完整性密钥。

用来保护 RRC 控制信令不被篡改或伪造。

K_UPenc:

User Plane encryption key, 用户面加密密钥。

用来加密用户数据的空口传输。

为什么 RRC 和 UP 要分开?

因为:

- RRC 是控制信令, 篡改后可能影响连接、切换、资源分配;
- UP 是用户业务数据, 重点是防窃听;
- 两类数据风险不同, 所以密钥分开。

考试怎么写:

K_RRCenc/K_RRCint 用于保护 UE 与 eNodeB 之间的 RRC 控制信令, 其中 enc 负责机密性, int 负责完整性。K_UPenc 用于用户面数据加密。RRC 和 UP 分离可以避免信令密钥和用户数据密钥相互影响, 降低密钥泄露范围。

注意 LTE 的一个常考点:

LTE 用户面主要强调加密, 用户面完整性保护不是强制重点; 5G 则增强了用户面完整性保护能力。

如果题干说“RRC 和用户面共用一个密钥”, 就写:

- 密钥分离不足;
- 控制信令 and 用户数据安全目标不同;
- 一个密钥泄露会同时影响信令和业务;
- 应派生 K_RRCenc、K_RRCint、K_UPenc 等不同密钥。

5. NH / NCC 是什么?

NH 是 Next Hop:

下一跳密钥材料, 用来在切换时派生目标基站密钥。

NCC 是 NH Chaining Counter:

NH 链计数器，用来标识现在用的是第几个 NH。

为什么需要 NH/NCC？

因为 UE 在移动时会从一个 eNodeB 切换到另一个 eNodeB。问题是：

新基站要有新密钥，但又不能每次切换都完整重新 AKA，否则太慢。

如果偷懒让旧基站直接把密钥给新基站：

- 快是快；
- 但旧基站知道新基站密钥；
- 旧基站被攻破后，攻击者可以继续跟踪和解密后续通信；
- 后向安全差。

NH/NCC 的作用就是：

- 提前准备下一跳密钥材料；
- 切换时用 NH 派生新 K_{eNB} ；
- 用 NCC 标识当前使用哪一个 NH；
- 尽量切断旧基站和新基站的密钥关系；
- 在安全性和切换时延之间折中。

考试怎么写：

NH 是 LTE 切换中用于派生下一跳基站密钥的密钥材料，NCC 用于标识 NH 链中的计数位置。NH/NCC 的目的，是在不每次重新执行 AKA 的情况下，为目标 eNodeB 提供新的密钥材料，并减少源 eNodeB 推导目标 eNodeB 密钥的能力，从而增强后向安全。

6. 这些名词在题里怎么用来抓漏洞？

题干说法	你应该想到的漏洞	答题方向
直接用 K_{ASME} 保护所有通信	密钥分离不足	应派生 NAS、AS、RRC、UP 不同密钥
NAS 加密和完整性用同一个密钥	加密/完整性密钥未分离	K_{NASenc} 和 K_{NASint} 应分开
eNodeB 拿到 K_{ASME}	基站权限过大	eNodeB 只应获得 K_{eNB}
RRC 和 UP 共用密钥	信令和用户面未分离	派生 $K_{RRCenc}/K_{RRCint}/K_{UPenc}$

题干说法	你应该想到的漏洞	答题方向
旧 eNodeB 把 K_eNB 发给新 eNodeB	后向安全差	使用 NH/NCC 或核心网参与派生
每次切换都沿用同一个 K_eNB	密钥更新不足	切换时派生新 K_eNB
没有 NCC 或计数不同步	切换密钥状态混乱	需要 NH 链计数器同步

最简单的记忆版：

K_ASME 是 LTE 的“大根”。
 K_NASenc/K_NASint 保护 UE 到核心网 MME 的 NAS 信令。
 K_eNB 是给基站用的“接入层根”。
 K_RRCenc/K_RRCint 保护控制信令 RRC。
 K_UPenc 保护用户数据。
 NH/NCC 是切换时用来生成下一跳基站密钥、改善后向安全的。

可能题干形式

例如：

某 LTE 系统中，UE 与 MME 完成 EPS-AKA 后生成 K_ASME，随后由 K_ASME 直接派生 K_eNB。切换到新 eNodeB 时，旧 eNodeB 将当前 K_eNB 直接发送给目标 eNodeB。请分析该方案的安全问题，并提出改进。

参考答案：旧 eNodeB 直接把 K_eNB 给目标 eNodeB

这题先抓关键词：K_ASME、K_eNB、旧 eNodeB 直接发送给目标 eNodeB。

1. K_ASME 和 K_eNB 的正常关系

- K_ASME 是 EPS-AKA 后的上层锚点密钥。
- K_eNB 是从 K_ASME 派生出来给 eNodeB 使用的接入层密钥。
- eNodeB 不应该知道 K_ASME，只应拿到较低层的 K_eNB。

2. 主要问题：旧基站知道目标基站密钥

- 切换后，目标 eNodeB 应该使用与源 eNodeB 隔离的新密钥。
- 如果旧 eNodeB 直接把当前 K_eNB 发给目标 eNodeB，那么旧基站仍然知道目标基站使用的密钥。
- 一旦旧 eNodeB 被攻破，攻击者就可以继续解密切换后的通信。

3. 后向安全不足

- 后向安全可以理解为：过去的旧节点或旧密钥泄露，不应影响未来通信。
- 这里旧 eNodeB 掌握目标 eNodeB 密钥，所以旧节点出事会连累未来通信，后向安全差。

4. 密钥隔离不足

- 源基站和目标基站之间没有真正的密钥隔离。
- 如果多个切换都沿用或转发同一密钥，攻击面会不断扩大。

5. 改进方案

- 不应由旧 eNodeB 直接转交当前 K_{eNB} 。
- 应使用 NH/NCC 或由 MME/核心网参与派生新的目标基站密钥。
- 对低时延场景可以使用横向派生，但要认识到安全性较弱。
- 对安全要求高的场景使用纵向派生，使目标 K_{eNB} 基于 NH 生成，切断源基站和目标基站密钥关系。
- 切换后及时更新密钥，并区分 RRC、UP、加密和完整性密钥。

一句话版：

旧 eNodeB 直接把 K_{eNB} 发给目标 eNodeB，会导致旧基站知道切换后的通信密钥，旧基站一旦被攻破就能影响未来通信，后向安全和密钥隔离都很差。应使用 NH/NCC 或核心网参与派生目标基站新密钥。

或者：

某系统为了降低切换时延，不重新执行 AKA，而是让源基站把密钥交给目标基站。请分析其对前向安全和后向安全的影响。

参考答案：为了低时延让源基站交密钥

这题先抓关键词：**降低切换时延、不重新 AKA、源基站把密钥交给目标基站。**

1. 先说明这样做的优点

- 不重新执行 AKA 可以减少信令交互。
- 切换速度更快，适合高速移动或实时业务。
- 但这是用安全性换时延。

2. 后向安全问题最明显

- 源基站把密钥交给目标基站，说明源基站知道目标基站后续要用的密钥。
- 如果源基站被攻破，攻击者可以继续解密用户切换后的通信。
- 这就是“过去的旧节点出事，连累未来通信”，所以后向安全差。

3. 前向安全也可能受影响

- 如果切换前后长期复用同一个密钥，那么目标基站或当前密钥泄露后，也可能解密切换前记录的历史通信。
- 也就是“现在出事，连累过去”，前向安全也不好。
- 如果目标基站只是获得新派生密钥，且不能反推旧密钥，则前向安全相对好一些；但题干说“把密钥交给目标基站”，通常说明隔离较差。

4. 根本问题：密钥更新和密钥隔离不足

- 切换不一定要重新 AKA，但必须有新的切换密钥。
- 源基站不应直接掌握目标基站后续密钥。

5. 改进方案

- 使用 NH/NCC 机制，提前准备下一跳密钥材料。
- 使用纵向派生，由核心网参与生成目标基站密钥，增强后向安全。
- 对时延敏感场景可使用横向派生，但要限制使用次数并定期由核心网刷新密钥。
- 切换后派生新的 RRC/UP 加密和完整性密钥。

一句话版：

让源基站直接把密钥交给目标基站虽然降低时延，但源基站会知道未来通信密钥，后向安全差；如果切换前后复用同一密钥，当前密钥泄露还可能影响历史通信，前向安全也差。应使用 NH/NCC 或核心网参与派生新密钥，在时延和安全之间折中。

或者：

某 5G 系统中 NAS、RRC、用户面都使用同一个密钥保护，请分析问题。

参考答案：5G 中 NAS、RRC、用户面共用同一密钥

这题先抓关键词：**NAS、RRC、用户面共用一个密钥。**

1. 违反密钥分离原则

- NAS、RRC、用户面属于不同层次、不同安全域。
- NAS 是 UE 和核心网 AMF/MME 之间的控制信令。
- RRC 是 UE 和基站之间的无线控制信令。
- 用户面是用户实际业务数据。
- 三者安全目标不同，不应使用同一个密钥。

2. 泄露影响范围过大

- 如果用户面密钥泄露，攻击者可能进一步影响 NAS 和 RRC 信令。
- 如果基站侧密钥泄露，可能影响核心网控制信令。
- 一个密钥出事，所有层都出事。

3. 加密和完整性也应分开

- NAS/RRC 不仅需要加密，还需要完整性保护。
- 加密密钥和完整性密钥应分离，避免同一密钥承担不同密码学用途。

4. 不符合 5G 分层密钥思想

- 5G 应从 K_{SEAF} 、 K_{AMF} 继续派生 K_{gNB} 、 K_{RRCenc} 、 K_{RRCint} 、 K_{UPenc} 、 K_{UPint} 等密钥。
- 不同层、不同用途、不同方向都应隔离。

5. 改进方案

- 用 KDF 从上层锚点密钥派生不同子密钥。
- NAS 使用 NAS 加密密钥和 NAS 完整性密钥。
- RRC 使用 RRC 加密密钥和 RRC 完整性密钥。
- 用户面使用 UP 加密密钥，必要时启用 UP 完整性密钥。
- 上行/下行、不同承载也应通过方向和承载参数区分。

一句话版：

NAS、RRC、用户面共用一个密钥会破坏密钥分离，使一个层次的密钥泄露影响所有层，并且混淆核心网信令、无线控制信令和用户数据的安全边界。应按 5G 密钥层次分别派生 NAS、RRC、UP 的加密和完整性密钥。

答题核心

1. 为什么要分层密钥？

因为不同安全域、不同协议层、不同通信对象的信任程度不同。

LTE/5G 里常见分层：

- 核心网长期根密钥只保存在 USIM 和归属网络；
- AKA 产生上层锚点密钥；
- NAS 密钥保护 UE 与核心网之间的控制信令；
- AS 密钥保护 UE 与基站之间的无线接入层信令和用户数据；
- RRC 和 UP 还要进一步分开；
- 加密密钥和完整性密钥也要分开。

可以写：

分层密钥的意义是限制密钥泄露影响范围，避免基站获得核心网长期密钥，同时支持不同层、不同方向、不同业务的独立保护。

2. 旧基站把密钥直接给新基站有什么问题？

这是典型考点。

问题：

- 旧基站如果被攻破，攻击者可以获得目标基站使用的密钥；
- 缺乏前向安全；
- 目标基站无法与旧基站密钥隔离；
- 横向派生速度快，但安全性较弱；
- 如果每次切换都沿用同一密钥，攻击面扩大。

3. NH/NCC 的作用

LTE 中 NH/NCC 是为了解决切换安全问题。

要点：

- NH 是 Next Hop，用于切换密钥派生；
- NCC 是 NH Chaining Counter，用于标识当前使用第几个 NH；
- 横向派生快，但前向安全较弱；
- 纵向派生基于 NH，能切断源基站和目标基站密钥关系；
- X2 切换快，但安全性相对弱；
- S1 切换需要 MME 参与，安全性更强但时延更高。

4. 5G 可怎么增强？

可以写：

- 使用 K_SEAF / K_AMF / K_gNB / K_RRC / K_UP 分层；
- 支持 NAS、RRC、UP 不同密钥；
- 用户面完整性保护增强；
- 使用 SUCI 保护永久身份；
- SBA 服务之间使用认证、授权和 TLS；
- 漫游使用 SEPP 保护运营商之间的边界。

这类题的标准模板

LTE/5G 密钥体系的核心不是“一个密钥保护所有内容”，而是从长期根密钥逐层派生出不同层、不同用途、不同方向的密钥。这样可以实现密钥隔离、降低泄露影响、支持切换和更新。

如果切换时直接复用旧 K_{eNB} 或让旧基站把密钥交给新基站，会导致旧基站或被攻破基站

能够推导后续通信密钥，破坏前向安全。改进方式是引入 NH/NCC 或由核心网参与派生新密钥，区分横向派生和纵向派生，并根据安全需求在时延和安全性之间折中。

三、很可能：WLAN / WEP / WPA / WPA2 / WPA3 方案分析

可能性：★★★★

去年第 2 题已经考了 WEP 的功能原理和安全缺陷，属于 10 分简答。但 WLAN 是课程前大部分重点，而且非常适合做分析题。

最后一道可能不直接问“WEP 缺陷”，而是给一个无线局域网方案，让你分析为什么不安全、如何升级。

可能题干形式

例如：

某校园 WLAN 采用共享口令认证，使用 RC4 加密，IV 长度为 24 bit，完整性校验采用 CRC32。请分析该方案的安全缺陷，并提出升级方案。

参考答案：校园 WLAN 使用 RC4 + 24 bit IV + CRC32

这题基本就是 WEP 分析题。抓关键词：**共享口令、RC4、24 bit IV、CRC32**。

1. 认证弱

- 共享口令意味着所有用户知道同一个秘密。
- 一人泄露会影响整个 WLAN。
- 难以撤销某个单独用户，只能全网改密码。

2. RC4 + 24 bit IV 容易密钥流复用

- WEP 类方案通常用 `IV || Key` 输入 RC4 生成密钥流。
- 24 bit IV 太短，在高流量校园网中很快会重复。
- IV 重复会导致 RC4 密钥流重复，从而出现：

$$C_1 \oplus C_2 = P_1 \oplus P_2$$

- 攻击者收集大量数据包后，可以分析明文关系甚至恢复密钥。

3. RC4 本身存在历史弱点

- WEP 中 RC4 的密钥调度方式存在弱 IV 问题。
- 攻击者可通过收集大量无线包进行统计分析。

4. CRC32 不能防恶意篡改

- CRC32 是检错码，不是 MAC。
- 它没有密钥，攻击者修改数据后可以同步修改 CRC。

- 因此不能提供真正完整性保护。

5. 升级方案

- 不应继续使用 WEP/RC4/CRC32。
- 校园或企业场景应使用 WPA2-Enterprise 或 WPA3-Enterprise。
- 使用 802.1X + EAP + RADIUS 做每用户认证。
- 数据保护使用 CCMP/GCMP，也就是 AES-CCM/AES-GCM。
- 对用户进行独立账号、证书或凭据管理，便于审计和撤销。

一句话版：

该方案类似 WEP，问题是共享静态口令、RC4 密钥流、24 bit IV 太短导致 IV 重复、CRC32 不能防篡改。应升级到 WPA2/WPA3-Enterprise，使用 802.1X/EAP/RADIUS 和 CCMP/GCMP。

这基本就是 WEP 分析题。

或者：

某企业 WLAN 使用 WPA2-PSK，所有用户共享同一个密码。请分析其安全问题，并提出改进建议。

参考答案：企业 WLAN 使用 WPA2-PSK 且全员共享密码

这题抓关键词：**企业 WLAN、WPA2-PSK、所有用户共享同一个密码。**

1. 不适合企业场景

- WPA2-PSK 更适合家庭或小型网络。
- 企业用户多、人员流动大，所有人共享一个密码会带来管理风险。

2. 难以撤销单个用户

- 某个员工离职或泄露密码后，无法只撤销这个人。
- 必须修改全网密码，并通知所有合法用户，运维成本高。

3. 缺少用户级身份认证和审计

- 所有人使用同一个 PSK，网络只能知道“有人知道密码”，不能准确知道是谁。
- 不利于访问控制、行为审计和责任追踪。

4. 弱口令可能遭受离线字典攻击

- 攻击者捕获 WPA2 四次握手后，可以对 PSK 做离线猜测。
- 如果共享密码不够强，就可能被破解。

5. 改进方案

- 企业应使用 WPA2-Enterprise 或 WPA3-Enterprise。

- 使用 802.1X + EAP + RADIUS。
- 每个用户使用独立账号、证书或 SIM/证书凭据。
- 可按用户、部门、设备分配权限和 VLAN。
- 员工离职时只撤销该用户账号或证书，不影响全网。
- 若是小型网络，至少使用强 PSK 并定期更换；但企业优先用 Enterprise。

一句话版：

WPA2-PSK 全员共享密码会导致难以撤销单个用户、无法审计到个人、密码泄露影响全网，并可能遭受离线字典攻击。企业场景应改用 WPA2/WPA3-Enterprise，通过 802.1X/EAP/RADIUS 实现每用户认证和权限控制。

或者：

某 WLAN 系统使用四次握手生成 PTK，但没有正确检查重放计数器。请分析可能攻击。

参考答案：WPA2 四次握手不检查重放计数器

这题抓关键词：**四次握手、PTK、没有正确检查重放计数器**。

1. 四次握手的正常作用

- AP 和 STA 通过 ANonce、SNonce、双方 MAC 地址和 PMK 派生 PTK。
- PTK 进一步分成 KCK、KEK、TK 等子密钥。
- 握手消息需要 MIC 和重放计数器保护，防止被重放。

2. 不检查重放计数器的风险

- 攻击者可以记录一次合法握手消息，之后重新发送。
- 如果终端接受旧消息，就可能重新安装已经使用过的 PTK 或 GTK。
- 这会导致 packet number / nonce 被重置或重复使用。

3. 可能导致密钥重装类攻击

- 密钥重装后，同一密钥下的 nonce/计数器可能重复。
- 对 CTR/CCMP/GCMP 类加密来说，nonce 重复会导致密钥流复用。
- 攻击者可能进一步重放、解密部分流量或注入伪造数据包。

4. 完整性和会话状态被破坏

- 四次握手不仅生成密钥，还确认双方状态。
- 重放计数器错误会让旧状态覆盖新状态，使协议状态混乱。

5. 改进方案

- 严格检查 EAPOL-Key replay counter。
- 已安装的密钥不应因重放消息而重复安装。
- 每次密钥安装时确保 packet number 不回滚。

- 对握手消息使用 MIC 验证。
- 使用已修复 KRACK 类问题的客户端和 AP 实现。

一句话版：

四次握手如果不正确检查重放计数器，攻击者可以重放握手消息，诱导终端重新安装旧密钥，导致 nonce/packet number 重用，从而引发密钥重装、重放、解密或注入攻击。应严格检查重放计数器，禁止重复安装密钥。

WEP 重点答题点

1. 认证弱

- 开放系统认证几乎等于无认证；
- 共享密钥认证会泄露明文-密文对；
- 攻击者可利用挑战和响应推导密钥流。

2. IV 太短

- WEP IV 只有 24 bit；
- 在高流量网络中很快重复；
- IV 重复导致 RC4 密钥流重复；
- 可通过密文异或获得明文关系。

3. RC4 密钥调度弱点

- WEP 使用 IV || Key 作为 RC4 输入；
- 某些弱 IV 会泄露密钥信息；
- 可通过收集大量数据包恢复密钥。

4. CRC32 不能防篡改

- CRC32 是检错码，不是密码学 MAC；
- 线性结构导致可预测修改；
- 不能防止恶意篡改。

5. 密钥管理差

- 多用户共享长期静态密钥；
- 缺乏自动更新；
- 一人泄露影响全网；
- 难以撤销单个用户权限。

改进方案

- 使用 WPA2-Enterprise / WPA3-Enterprise;
- 使用 802.1X + EAP + RADIUS 做身份认证;
- 使用四次握手从 PMK 派生 PTK;
- 使用 CCMP / GCMP, 也就是 AES-CCM 或 AES-GCM;
- 使用 MIC/AEAD 完整性保护;
- 使用 TKIP 只能作为过渡, 不推荐;
- 家庭场景可用 WPA3-Personal 的 SAE, 抵抗离线字典攻击;
- 对企业场景应避免共享 PSK, 采用每用户身份认证。

如果考 WPA2 四次握手

重点写:

- PMK 是长期或会话主密钥;
- ANonce + SNonce + 双方 MAC 地址参与派生 PTK;
- PTK 分为 TK、KCK、KEK 等子密钥;
- KCK 保护 EAPOL-Key 消息完整性;
- KEK 加密 GTK;
- TK 用于数据加密;
- 重放计数器防止握手重放;
- 如果 nonce 重用、MIC 检查不严或重放计数器处理错误, 可能导致密钥重装或重放攻击。

四、较可能: 5G 身份隐私、SUPI/SUCI、5G-AKA、漫游安全分析

可能性: ★★★★★

去年第 6 题考了“5G 匿名的新方法, 分析优缺点”, 是 15 分。说明老师喜欢问“新机制解决什么问题, 还有什么缺陷”。

今年如果出最后分析题, 5G 很适合综合考:

- SUPI / SUCI
- 5G-AKA
- SEAF / AUSF / UDM / ARPF
- K_SEAF / K_AMF / K_gNB
- SEPP
- SBA 安全
- 用户面完整性保护

- 漫游安全
- 降级攻击

可能题干形式

例如：

某 5G 系统为了保护用户隐私，终端不再明文发送 SUPI，而是发送 SUCI。但在漫游场景中，拜访网络仍然负责转发认证请求。请分析 SUCI 的作用、局限性以及还需要哪些安全机制。

参考答案：SUCI 在漫游中的作用和局限

这题抓关键词：**SUPI 不明文、SUCI、漫游、拜访网络转发认证请求。**

1. SUCI 的作用

- SUPI 是 5G 用户永久身份，类似以前的 IMSI。
- 如果 SUPI 在空口明文发送，攻击者可以监听并长期跟踪用户。
- SUCI 是把 SUPI 隐藏后的身份，通常用归属网络公钥加密生成。
- 这样拜访网络和空口攻击者一般不能直接看到用户永久身份。

2. SUCI 主要解决“永久身份暴露”问题

- 它能降低 IMSI Catcher 类攻击获取永久身份的风险。
- 即使攻击者监听注册过程，也不容易直接得到 SUPI。

3. SUCI 的局限性

- SUCI 不等于完全匿名。
- 拜访网络仍然能看到用户接入位置、时间、服务请求等元数据。
- 攻击者仍可能通过流量模式、位置变化、临时身份关联来跟踪用户。
- 如果终端降级到 4G/2G，仍可能暴露 IMSI/SUPI。
- 如果归属网络公钥配置错误或算法被降级，也会影响隐私。

4. 漫游场景还需要 SEPP

- 拜访网络和归属网络之间存在运营商边界。
- 5G 使用 SEPP 保护 PLMN 之间的漫游信令，提供认证、完整性、机密性和拓扑隐藏。
- SEPP 保护的是运营商之间的接口，不是 UE 到 gNB 的空口。

5. 还需要哪些安全机制

- 5G-AKA 实现 UE 与网络认证，并由归属网络参与认证。
- NAS/AS 安全保护后续信令和无线链路。
- 防降级机制，避免攻击者诱导终端回落到弱旧网络。
- 临时身份更新，减少长期关联。

- 服务接口之间使用认证、授权和 TLS。

一句话版：

SUCI 的作用是隐藏 SUPI，减少永久身份在空口暴露，防 IMSI Catcher 类跟踪。但 SUCI 不能隐藏所有元数据，也不能单独防降级、流量分析和漫游信令风险。还需要 5G-AKA、NAS/AS 安全、防降级、临时身份更新和 SEPP 保护运营商边界。

或者：

某运营商在 5G 中使用 SUPI/SUCI 保护用户身份，但允许终端回落到 4G/2G。请分析仍可能存在的隐私风险。

参考答案：5G 有 SUCI 但允许回落到 4G/2G

这题抓关键词：**5G 使用 SUCI、允许回落到 4G/2G。**

1. 5G 中 SUCI 的保护作用有限于 5G 流程

- 在正常 5G 注册中，SUCI 可以避免 SUPI 明文暴露。
- 但如果终端被诱导回落到旧系统，5G 的 SUCI 保护可能无法继续发挥作用。

2. 2G 风险最大

- 2G 缺少网络对用户的强双向认证，用户难以确认基站真假。
- 伪基站可以诱导终端接入，并请求 IMSI。
- 攻击者可以获得永久身份并跟踪用户。

3. 4G 也仍有身份暴露场景

- LTE 使用 GUTI/S-TMSI 减少 IMSI 暴露，但它们不是永久解决方案。
- 在临时身份失效、初次接入或异常恢复时，网络仍可能请求 IMSI。
- 攻击者可以通过伪基站、拒绝服务或降级方式诱导身份暴露。

4. 降级攻击和隐私跟踪

- 攻击者可以干扰 5G 信号，让终端认为 5G 不可用，转而接入旧网络。
- 即使拿不到 SUPI，也可能通过位置、时间、临时身份变化进行关联跟踪。

5. 改进方案

- 禁止或限制回落到不安全的 2G 网络。
- 对降级过程做策略控制和用户/网络侧检测。
- 尽量使用 5G SA 和 SUCI 流程。
- 加强临时身份更新和伪基站检测。
- 对必须回落的场景，要求更强认证和加密算法，拒绝空加密或弱算法。

一句话版：

SUCI 只能保护 5G 流程中的永久身份隐藏。如果允许回落到 4G/2G，攻击者可能通过降级或伪基站诱导终端暴露 IMSI/SUPI，或进行位置关联跟踪。应限制弱网络回落，加入防降级策略和伪基站检测。

或者：

某 5G 网络采用 SBA 架构，网络功能之间通过 API 调用通信。请分析相比 4G 的新安全边界和防护机制。

参考答案：5G SBA 架构中的 API 安全

这题抓关键词：**SBA、网络功能之间 API 调用、相比 4G 的新边界。**

1. SBA 带来的变化

- 4G 核心网更像固定网元之间的专用接口通信。
- 5G 核心网采用 SBA，网络功能 NF 通过服务化 API 相互调用。
- 这提高了灵活性，但也扩大了 API 暴露面。

2. 新的安全边界

- 边界不再只是“核心网内部”和“外部网络”之间。
- 每个 NF、每个服务接口、服务注册发现过程都成为安全边界。
- 还要考虑云化、虚拟化、切片、MEC 等新场景。

3. 可能风险

- 伪造 NF 注册到网络中。
- 未授权 NF 调用敏感服务接口。
- API 被滥用、越权访问或参数篡改。
- 服务发现/注册信息泄露导致拓扑暴露。
- 某个 NF 被攻破后横向移动到其他 NF。
- API DoS 影响核心网服务可用性。

4. 防护机制

- NF 之间必须进行双向认证。
- API 调用需要授权和最小权限控制。
- 使用 TLS 保护服务接口的机密性和完整性。
- 服务注册、发现和令牌发放要受保护。
- 记录日志并进行审计和异常检测。
- 网络切片之间要隔离。
- 跨运营商边界使用 SEPP。

一句话版：

5G SBA 把核心网能力服务化，安全边界从传统网元边界扩展到每个 NF 和 API 接口。风险包括伪造 NF、越权调用、API 滥用、服务发现泄露和横向移动。应通过 NF 认证、授权、TLS、最小权限、日志审计、切片隔离和 SEPP 进行防护。

答题核心

1. SUPI / SUCI

- SUPI 是用户永久身份；
- SUCI 是隐藏后的用户身份；
- UE 使用归属网络公钥加密 SUPI 得到 SUCI；
- 空口不再明文传输 SUPI；
- 可降低 IMSI Catcher 对永久身份的捕获风险。

2. SUCI 的局限

- 不能隐藏所有元数据；
- 无法完全防止位置跟踪和流量分析；
- 如果回落到 2G/3G/4G，仍可能暴露 IMSI；
- 如果归属网络公钥配置错误或算法降级，会有风险；
- SUCI 主要保护永久身份，不等于完整匿名。

3. 5G-AKA

- 继承 AKA 思路；
- 实现 UE 与网络之间认证；
- 由归属网络参与认证；
- 生成 K_SEAF、K_AMF 等后续密钥；
- 认证完成后仍需要 NAS 安全模式命令建立 NAS 加密和完整性保护；
- AKA 本身不等于所有后续通信都自动安全。

4. 漫游安全 SEPP

- 2G/3G/4G 漫游中 SS7/Diameter 存在边界信任问题；
- 5G 引入 SEPP 保护运营商之间的信令边界；
- SEPP 不是保护 UE 到 gNB 的空口，而是保护 PLMN 之间的互联接口；
- 可防止漫游信令被篡改、伪造、泄露。

5. SBA 安全

- 5G 核心网服务化；

- 网络功能 NF 之间通过服务接口通信；
- 需要 NF 认证、授权、TLS、访问控制、日志审计；
- API 暴露面增加，所以服务注册、发现、授权很重要。

高分总结句

5G 的身份隐私不是简单“把 IMSI 改名”，而是通过 SUPI/SUCI、5G-AKA、密钥层次、NAS/AS 分层、SEPP 和 SBA 服务安全共同构成体系。SUCI 解决的是永久身份空口暴露问题，但不能单独解决降级、流量分析、漫游边界和核心网服务接口安全问题。

五、较可能：TETRA 空口加密、传输加密、端到端加密综合分析

可能性：★★★☆☆

去年第 5 题已经考了：

TETRA 空口加密和端到端加密的密钥流同步区别

这说明 TETRA 是老师关注点。TETRA 的特点是“专业集群通信”，非常适合出分析题，尤其是和 GSM 对比。

可能题干形式

例如：

某应急通信系统采用 TETRA，只在 MS 与基站之间进行空口加密，SwMI 内部和调度台之间不做端到端加密。请分析这种设计能抵抗哪些威胁，不能抵抗哪些威胁，并提出改进。

参考答案：TETRA 只做空口加密，不做端到端加密

这题抓关键词：TETRA、只在 MS 与基站之间空口加密、SwMI 和调度台不做端到端加密。

1. 能抵抗什么

- 空口加密能保护终端 MS 到基站/SwMI 之间的无线链路。
- 普通无线监听者不能直接听到语音或业务明文。
- 可降低空口窃听、空口流量分析和部分伪造风险。

2. 不能抵抗什么

- 空口加密只保护无线段，不保护业务在 SwMI、核心网、调度台内部的处理过程。
- SwMI、调度台或中间网络节点仍可能看到业务明文。
- 内部人员、被攻破的调度台、核心网节点可以窃听或篡改业务内容。
- 如果传输链路没有保护，基站到核心网之间也可能被监听。

3. 为什么 TETRA 场景更敏感

- 应急通信涉及公安、消防、调度等敏感业务。
- 一旦调度命令或组呼内容泄露，可能影响公共安全。
- 但应急系统又需要调度监听、合法监听和统一指挥，所以不能简单“一刀切”全加密。

4. 改进方案

- 保留空口加密，防无线窃听。
- 对基站、SwMI、调度台之间链路增加传输加密。
- 对特别敏感的组呼或点对点通信启用端到端加密。
- 建立群组密钥管理、成员撤销、调度台授权访问机制。
- 对调度台和核心网节点做访问控制、日志审计和安全加固。

一句话版：

空口加密只能防无线侧窃听，不能防 SwMI、调度台和核心网内部看到明文。应急通信还需要传输加密、端到端加密、调度授权、群组密钥管理和审计机制共同保护。

或者：

某 TETRA 群组通信系统要求既支持调度监听，又保护组内语音内容。请分析空口加密、传输加密和端到端加密的取舍。

参考答案：TETRA 群组通信中调度监听与内容保护的取舍

这题抓关键词：**群组通信、调度监听、保护组内语音、空口/传输/端到端加密。**

1. 空口加密的作用和局限

- 空口加密保护 MS 到基站之间的无线链路。
- 它能防止普通无线监听者窃听。
- 但 SwMI、调度台和核心网节点仍可能看到明文，因此方便调度监听。
- 缺点是无法防内部节点泄露。

2. 传输加密的作用和局限

- 传输加密保护基站、交换系统、核心网之间的链路。
- 可防止中间传输链路被监听或篡改。
- 但业务处理节点内部仍可能看到明文。

3. 端到端加密的作用和局限

- 端到端加密保护发送终端到接收终端的业务内容。
- 中间网络、SwMI、基站通常无法看到明文。
- 机密性最强，但会让调度监听、合法监听、迟到加入、组成员管理变复杂。

4. 调度监听和端到端加密的冲突

- 如果端到端加密完全排除调度台，调度台无法监听和指挥。
- 如果让调度台也持有组密钥，又要防止调度台权限过大或密钥泄露。
- 所以需要明确哪些调度台、哪些角色有权加入解密集合。

5. 折中方案

- 普通业务使用空口加密 + 传输加密，保证调度可见。
- 高敏感业务使用端到端加密，并把授权调度台作为合法组成员或使用专门授权密钥。
- 使用分级密钥：组密钥、调度密钥、业务密钥分开。
- 成员加入/退出时更新组密钥，防止新成员看历史、旧成员看未来。
- 合法监听必须有权限控制和审计。

一句话版：

空口加密便于调度但保护范围有限；传输加密保护网络链路但不防处理节点；端到端加密机密性最强但会增加调度监听、合法监听和群组密钥管理复杂度。应按业务敏感级别分层使用，并对调度台进行授权和审计。

或者：

某 TETRA 系统中端到端加密由终端自行同步密钥流，但群组成员可能迟到加入通话。请分析同步问题和解决方案。

参考答案：TETRA 端到端加密的密钥流同步与迟到加入

这题抓关键词：**端到端加密、终端自行同步密钥流、群组成员迟到加入。**

1. 为什么会有同步问题

- 很多语音加密本质上是生成密钥流，然后和语音数据异或。
- 发送端和接收端必须使用同一密钥、同一 IV、同一帧计数位置。
- 如果接收端密钥流位置不对，解密出来就是乱码。

2. 迟到加入为什么麻烦

- 群组成员迟到加入时，前面的帧、IV 或同步状态可能没收到。
- 它不知道当前密钥流进行到哪里。
- 如果直接开始解密，可能无法恢复明文。

3. 丢包和切换也会造成同步失败

- 无线链路容易丢包。
- 终端可能切换信道或进入弱覆盖区域。
- 如果缺少重新同步机制，后续语音都可能无法解密。

4. 安全风险

- 不能为了同步方便而明文发送业务内容。

- 也不能让未授权成员通过同步信息获得不该听的群组密钥。
- 如果旧成员退出后仍能同步和解密，说明组密钥更新不足。

5. 解决方案

- 周期性发送受保护的同步信息，例如帧号、同步向量、密钥流位置。
- 每个语音帧带有加密所需的帧计数或 IV 信息。
- 设计迟到加入流程：认证成员身份后，下发当前组密钥或会话密钥状态。
- 成员加入/退出时更新组密钥。
- 对同步信息做完整性保护，防止攻击者篡改导致全组失步。

一句话版：

端到端加密要求收发双方密钥流同步。迟到加入成员可能不知道当前 IV、帧号或密钥流位置，导致无法解密。应使用受保护的同步向量、帧计数、重新同步机制和群组密钥更新，既保证能加入通话，又不破坏授权和机密性。

答题核心

1. 空口加密

保护范围：

- MS 到基站之间的无线链路；
- 防止无线窃听；
- 防止无线侧流量分析和部分伪造。

不足：

- 基站、SwMI、中间网络节点仍可看到明文；
- 不能防止核心网络内部人员或中间节点窃听；
- 不保护端到端业务内容。

2. 传输加密

保护范围：

- 基站到交换机、核心网之间的有线或微波传输链路；
- 防止网络传输链路被监听或篡改。

不足：

- 中间处理节点可能仍能看到明文；
- 不能保证真正端到端机密性。

3. 端到端加密 E2EE

保护范围：

- 发送终端到接收终端；
- 中间 SwMI、基站、传输网络不能看到业务明文。

不足和难点：

- 群组通信中密钥管理复杂；
- 迟到加入、成员退出、调度监听、合法监听都变复杂；
- 密钥流同步困难；
- 需要明确谁有权解密；
- 可能影响应急调度和监管需求。

4. TETRA 和 GSM 对比

- GSM 主要面向公网移动通信；
- TETRA 面向专网、应急、公安、消防、调度；
- GSM 更重视用户接入和空口加密；
- TETRA 更重视群组通信、调度、组呼、端到端保护和合法监听之间的平衡；
- TETRA 安全需求更复杂，因为有群组、组织、调度台、应急优先级等业务。

高分总结句

空口加密只能保护无线链路，不能保护业务内容经过核心网和调度系统时的机密性；端到端加密能保护业务明文，但会带来群组密钥管理、密钥流同步、迟到加入、合法监听和调度控制等复杂问题。因此 TETRA 的安全设计通常需要空口加密、传输加密、端到端加密和密钥管理机制配合使用。

六、可能：给一个新无线系统，让你做威胁建模和安全体系设计

可能性：★★★☆☆

资料中有一章专门是“无线通信的安全威胁和安全体系”，很适合作为最后分析题。它比具体协议更综合。

可能题干形式

例如：

某校园部署一套无线物联网系统，包含终端、无线接入点、网关、云平台和管理后台。终端通过无线链路上传数据，网关与云平台通过公网通信。请从无线通信安全角度分析可能威胁，并设计安全体系。

参考答案：校园无线物联网系统威胁建模与安全设计

这题抓关键词：**终端、无线接入点、网关、云平台、管理后台、公网通信。**

1. 先分安全域

- 终端域：传感器、摄像头、门禁设备等。
- 无线接入域：无线链路、AP、基站或网关入口。
- 网关域：协议转换、数据汇聚、边缘处理。
- 云平台域：数据存储、业务处理、API。
- 管理域：后台账号、权限、配置、日志。

2. 可能威胁

- 无线链路被窃听，导致数据泄露。
- 攻击者伪造终端上传假数据。
- 攻击者重放旧数据，造成错误状态判断。
- 终端被盗或克隆，密钥泄露。
- AP 或网关被伪造，诱导终端连接。
- 网关到云平台的公网链路被中间人攻击。
- 管理后台弱口令或越权访问。
- 大量伪造设备接入导致拒绝服务。

3. 安全目标

- 终端和网关之间要双向认证。
- 无线链路要加密和完整性保护。
- 数据包要有序列号、时间戳或 nonce 防重放。
- 设备身份和密钥要安全存储。
- 管理后台要有访问控制和审计。
- 系统要保证可用性和设备可撤销。

4. 机制设计

- 每个终端使用独立身份和密钥，不使用全网共享密钥。
- 终端与网关之间使用 AEAD 或加密 + MAC。
- 网关与云平台之间使用 TLS，并校验证书。
- 使用 KDF 派生加密密钥、完整性密钥和会话密钥。
- 数据包加入序列号和滑动窗口。
- 终端支持安全启动、固件签名和安全 OTA。

- 管理后台使用强认证、最小权限、日志审计和告警。
- 设备丢失后能吊销证书或密钥。

一句话版：

这类题要按安全域分析：终端、无线链路、网关、云平台、管理后台。威胁包括窃听、伪造、篡改、重放、设备克隆、公网中间人和后台越权。应使用双向认证、AEAD、TLS、防重放、设备证书、密钥分离、吊销和审计机制。

或者：

某专用无线通信系统用于应急调度，请分析其面临的安全威胁、需要满足的安全目标和可采用的安全机制。

参考答案：应急调度专用无线通信系统安全分析

这题抓关键词：**专用无线通信、应急调度**。

1. 面临的威胁

- 空口窃听：攻击者监听调度语音和指令。
- 伪造终端：非法用户冒充合法人员加入系统。
- 伪基站或假调度台：诱导终端连接或接收假命令。
- 篡改和重放：重放旧调度命令或修改控制消息。
- 拒绝服务和干扰：阻断应急通信。
- 设备丢失：终端落入攻击者手中，密钥泄露。
- 内部滥用：调度台或管理员权限过大。

2. 安全目标

- 机密性：调度语音、位置、指令不能被无关人员监听。
- 完整性：调度命令不能被篡改。
- 身份认证：终端、基站、调度台要确认彼此身份。
- 防重放：旧命令不能被重复执行。
- 可用性：应急通信不能轻易被阻断。
- 访问控制：不同角色只能访问授权组呼和频道。
- 可审计性：关键操作要留日志。

3. 安全机制

- 终端和网络之间进行双向认证。
- 空口加密防止无线窃听。
- 对关键控制信令加入 MAC 或数字签名。
- 使用序列号、时间戳或挑战响应防重放。

- 对敏感语音或特殊组启用端到端加密。
- 设计群组密钥管理，成员加入/退出时更新密钥。
- 丢失终端可远程禁用或撤销密钥。
- 调度台权限分级，关键操作审计。
- 对干扰和 DoS 采取冗余链路、频率管理和优先级调度。

一句话版：

应急调度系统不仅要保密，还要强认证、完整性、防重放和高可用。应采用空口加密、端到端加密、群组密钥管理、终端撤销、调度权限控制、日志审计和抗干扰机制。

答题框架

这种题建议按以下顺序答：

1. 先分安全域

- 接入域：终端、SIM/USIM/设备、AP/基站；
- 网络域：基站、交换机、核心网、网关、服务器；
- 用户域：用户、终端、本地密钥、口令、PIN；
- 应用域：业务应用、调度系统、云平台；
- 管理域：配置、日志、权限、审计；
- 如果是 5G，还可以写 SBA、MEC、漫游、UPF、SEPP。

2. 再列威胁

常见威胁：

- 窃听；
- 篡改；
- 伪造；
- 重放；
- 冒充；
- 中间人攻击；
- 非授权接入；
- 流量分析；
- 拒绝服务；
- 密钥泄露；
- 身份隐私泄露；
- 降级攻击；

- 切换攻击；
- 设备丢失或克隆；
- 管理后台被攻破。

3. 对应安全服务

威胁	对应安全服务
冒充、伪基站	认证
非授权接入	访问控制
窃听	保密性
篡改、插入、删除	完整性
重放	新鲜性、序列号、时间戳
抵赖	数字签名、日志审计
流量分析	身份隐藏、临时身份、最小化元数据
DoS	可用性、频率限制、入侵检测

4. 给出机制设计

- 双向认证；
- 加密；
- MAC/AEAD 完整性保护；
- 序列号/nonce/时间戳防重放；
- KDF 密钥派生；
- 分层密钥体系；
- 定期密钥更新；
- 临时身份或匿名机制；
- 访问控制；
- 安全日志和审计；
- 安全配置和密钥存储；
- 设备吊销机制；
- 管理后台权限隔离。

高分总结句

无线通信安全设计不能只说“加密”，而要从威胁、攻击位置、安全域、安全目标和安全机制几个层次展开。一个完整方案至少应覆盖认证、保密性、完整性、防重放、密钥管理、访问控制、身份隐私和可用性。

七、可能：认证协议 / 重放 / 中间人 / 新鲜性分析

可能性：★★★☆☆

去年第 1 题考了“重放攻击应对策略 3 种”。今年最后一题可能把它扩展成一个具体协议分析。

可能题干形式

例如：

A 和 B 共享密钥 K。A 向 B 发送 IDA 和随机数 NA，B 返回 E_K(NA)，A 即认为 B 合法。请分析该认证协议存在的问题，并提出改进。

参考答案：共享密钥挑战响应协议分析

这题抓关键词：**共享密钥 K、随机数 NA、B 返回 E_K(NA)、A 认为 B 合法。**

1. 它解决了什么

- NA 是 A 发出的新鲜随机挑战。
- B 能返回 E_K(NA)，说明 B 可能知道共享密钥 K。
- 所以它可以在一定程度上让 A 认证 B。

2. 问题一：只有单向认证

- A 验证了 B，但 B 没有验证 A。
- 攻击者可能冒充 A 向 B 发起认证请求，诱导 B 参与协议。

3. 问题二：没有绑定双方身份和角色

- 返回内容只有 E_K(NA)，没有包含 IDA、IDB、方向或协议上下文。
- 在某些协议中可能发生反射攻击或未知密钥共享问题。
- B 的响应应该明确表示“我是 B，正在回应 A 的挑战”。

4. 问题三：没有形成会话密钥

- 协议只认证了一下 B 是否知道 K，没有派生新的会话密钥。
- 如果长期使用 K，密钥泄露影响所有历史和未来通信。

5. 问题四：缺少完整性保护整个会话

- 只加密 NA 不代表整个认证消息都完整。
- IDA、协议参数等也应被 MAC 保护。

6. 改进方案

- 使用双向挑战响应：A 发 NA，B 发 NB，双方都证明知道 K。
- 用 MAC 而不是单纯加密：

$$MAC_K(IDA||IDB||NA||NB||role)$$

- 在认证后用 KDF 派生会话密钥。

- 加入协议标识、方向标识和双方身份，防止反射和未知密钥共享。

一句话版：

该协议只能让 A 单向认证 B，且没有绑定双方身份、角色和会话上下文，也没有派生新会话密钥。应改成双向挑战响应，用 MAC 保护 IDA、IDB、NA、NB 和角色信息，并通过 KDF 生成会话密钥。

或者：

A 和 B 使用 Diffie-Hellman 交换密钥，但没有身份认证。请分析是否能抵抗中间人攻击。

参考答案：未认证 Diffie-Hellman 的中间人攻击

这题抓关键词：**Diffie-Hellman**、**没有身份认证**。

1. DH 本身解决什么

- Diffie-Hellman 可以让双方在公开信道上协商出共享密钥。
- 被动监听者不知道双方私有指数，通常无法计算会话密钥。

2. 但未认证 DH 不能防中间人攻击

- 如果没有签名、证书或预共享密钥认证，A 不知道收到的 DH 公共值是否真的来自 B。
- 攻击者 M 可以拦截 A 和 B 的 DH 参数。
- M 与 A 建立一个密钥，与 B 建立另一个密钥。
- A 以为自己在和 B 通信，B 也以为自己在和 A 通信，但所有消息都经过 M 解密、修改、再加密。

3. 安全结论

- 未认证 DH 可以抵抗被动窃听。
- 不能抵抗主动中间人攻击。
- 问题根源是密钥交换没有绑定身份。

4. 改进方案

- 使用数字证书对 DH 参数签名，例如 TLS/EAP-TLS。
- 使用预共享密钥对 DH 交换做 MAC 认证。
- 在密钥确认消息中加入双方身份和 DH 参数哈希。
- 使用成熟的认证密钥交换协议，不要自造协议。

一句话版：

Diffie-Hellman 只解决“协商密钥”，不自动解决“对方是谁”。没有身份认证时，攻击者可以分别与 A、B 建立两个密钥并转发消息，因此不能抵抗中间人攻击。应使用证书签名、

PSK-MAC 或 EAP-TLS 等认证密钥交换机制。

或者：

某系统使用时间戳防重放，但终端时间不同步。请分析问题。

参考答案：时间戳防重放但终端不同步

这题抓关键词：**时间戳防重放、终端时间不同步**。

1. 时间戳防重放的原理

- 消息中带发送时间。
- 接收方只接受时间在合理窗口内的消息。
- 过旧消息会被认为是重放。

2. 时间不同步会造成误拒绝

- 如果终端时钟慢或快，合法消息可能被认为过期或来自未来。
- 这会导致合法用户无法通信，影响可用性。

3. 窗口过大会降低安全性

- 为了容忍时间不同步，系统可能设置很大的时间窗口。
- 但窗口越大，攻击者重放旧消息的机会越多。
- 例如 5 分钟窗口内的旧消息可能仍被接受。

4. 时钟可被攻击者操纵

- 如果攻击者能干扰授时或让设备时钟回滚，就可能绕过防重放。
- 也可能制造大量认证失败，形成 DoS。

5. 改进方案

- 使用随机挑战 nonce 做认证，不完全依赖时间。
- 数据包使用递增序列号和滑动窗口。
- 时间戳只作为辅助，新鲜性主要由 nonce/sequence 保证。
- 使用安全时间同步，并限制允许的时间漂移。
- 对时钟异常进行告警和重新同步。

一句话版：

时间戳能防重放的前提是时钟同步。终端时间不同步会导致合法消息被拒绝，或不得不放大大时间窗口从而增加重放风险。应结合随机挑战、序列号、滑动窗口和安全时间同步，而不是只依赖时间戳。

常见漏洞

1. 单向认证

只证明一方身份，没有证明另一方身份。

改进：

- 双向挑战-响应；
- 双方都证明掌握密钥；
- 加入身份绑定。

2. 缺少新鲜性

没有随机数、时间戳或序列号。

改进：

- 加 nonce；
- 加时间戳；
- 加序列号；
- 加滑动窗口；
- 加挑战-响应机制。

3. MITM

Diffie-Hellman 如果没有认证，会被中间人攻击。

改进：

- 使用证书签名 DH 参数；
- 使用预共享密钥认证 DH；
- 使用 EAP-TLS；
- 使用带认证的密钥交换协议。

4. 反射攻击

协议两边消息格式相同，攻击者可能把挑战反射回去。

改进：

- 区分发起方/响应方；
- 在 MAC 中加入双方身份和角色；
- 加入方向标识。

5. 未绑定身份和密钥

可能发生未知密钥共享攻击。

改进：

- 在密钥确认消息中加入双方身份、随机数、会话上下文。

高分总结句

认证协议不仅要证明“对方知道密钥”，还要证明消息是新鲜的、身份是绑定的、双方角色明确、会话密钥没有被中间人替换，并且认证结果能和后续密钥使用绑定起来。

八、可能：用户面完整性保护与“只加密不认证”分析

可能性：★★★☆☆

资料里 LTE 和 5G 都反复提到：

- LTE 用户面主要加密，完整性保护不足；
- 5G 增强用户面完整性保护；
- aLTEr、IMSI Catcher、伪基站、DNS 劫持等攻击与用户面/控制面保护有关。

所以可能出一道：

某移动网络只对用户面数据加密，不做完整性保护。请分析风险。

参考答案：用户面只加密不做完整性保护

这题抓关键词：**用户面数据、只加密、不做完整性保护。**

1. 加密只保证看不懂，不保证不能改

- 用户面加密可以防止攻击者直接读取用户数据。
- 但如果没有完整性保护，攻击者可能修改、插入、删除或重放密文。
- 接收方可能无法发现数据已被恶意篡改。

2. 可能造成用户业务被劫持或干扰

- 如果用户访问的是没有端到端 TLS 的服务，攻击者可能篡改 DNS、HTTP 或其他明文应用数据。
- 即使链路层加密存在，缺少完整性仍可能被利用进行重定向、注入或会话干扰。

3. 控制面和用户面的差别

- 控制面信令通常更强调完整性，因为篡改控制信令会直接影响网络状态。
- 用户面承载真实业务数据，LTE 中用户面完整性不是强制重点。
- 5G 增强了用户面完整性保护能力，尤其适合工业控制、低时延高可靠业务。

4. 只靠应用层保护也不够理想

- TLS/HTTPS 可以保护端到端业务，但不是所有应用都正确使用。

- 网络层仍应对高安全业务提供完整性能力。

5. 改进方案

- 对高安全业务启用用户面完整性保护。
- 使用 AEAD 或加密 + MAC。
- 加密密钥和完整性密钥分离。
- 继续鼓励端到端 TLS/HTTPS、DoT/DoH、DNSSEC 等应用层保护。
- 使用序列号和重放窗口防止用户面重放。

一句话版：

用户面只加密只能防窃听，不能防篡改。攻击者可能修改、注入、删除或重放用户数据，造成 DNS/HTTP 劫持或业务干扰。应对重要业务启用用户面完整性保护，使用 AEAD/MAC、密钥分离、防重放和端到端 TLS。

答题要点

- 加密保护机密性，但不保证数据未被篡改；
- 用户面数据可能被修改、注入、重放；
- 如果 DNS、HTTP、应用流量没有额外 TLS，攻击者可能进行劫持或重定向；
- 控制面完整性保护强于用户面，但用户面承载真实业务数据；
- 5G 引入用户面完整性保护能力，尤其适合低时延、高可靠、工业控制等场景；
- 代价是计算和传输开销增加；
- 可按业务设置 Required / Preferred / Not Needed。

改进方案

- 用户面增加完整性保护；
- 使用 AEAD；
- 端到端应用层 TLS/HTTPS；
- 对高安全业务启用 UP integrity；
- 加密和完整性密钥分离；
- 对 DNS 使用 DoT/DoH 或运营商侧安全解析；
- 加入异常流量检测。

九、可能：漫游安全 / SEPP / SS7 / Diameter / 边界保护

可能性：★★☆

如果老师想考 5G 的新内容，这个方向也可能作为分析题。

可能题干形式

某运营商在 5G 漫游中仍然直接信任拜访网络传来的认证和位置更新信令。请分析风险，并说明 5G 为什么引入 SEPP。

参考答案：5G 漫游中过度信任拜访网络与 SEPP

这题抓关键词：**5G 漫游、直接信任拜访网络、认证和位置更新信令、SEPP。**

1. 风险：漫游边界不能默认可信

- 拜访网络和归属网络属于不同运营商安全域。
- 如果归属网络直接信任拜访网络传来的信令，恶意或被攻破的拜访网络可能伪造认证、位置更新或服务请求。

2. 可能攻击

- 查询或跟踪用户位置。
- 伪造漫游信令，诱导错误计费或错误授权。
- 篡改用户认证相关消息。
- 泄露用户身份、位置信息和网络拓扑。
- 对核心网服务接口进行滥用或 DoS。

3. 历史原因

- 2G/3G/4G 的 SS7/Diameter 漫游体系存在“运营商之间过度信任”的问题。
- 一旦信令网被滥用，就可能发生位置跟踪、短信截获、欺骗请求等攻击。

4. SEPP 的作用

- SEPP 是 Security Edge Protection Proxy，部署在运营商网络边界。
- 它保护 PLMN 之间的漫游信令。
- 提供跨运营商的认证、完整性、机密性和拓扑隐藏。
- 防止外部网络直接接触内部核心网功能。

5. SEPP 的边界要说清楚

- SEPP 保护的是运营商之间的接口，不是 UE 到 gNB 的空口。
- UE 到网络仍需要 5G-AKA、NAS 安全、AS 安全和 SUCI。

一句话版：

漫游场景中拜访网络和归属网络属于不同安全域，不能直接信任对方信令。否则可能出现位置跟踪、信令伪造、隐私泄露和错误授权。5G 引入 SEPP 是为了保护 PLMN 之间的漫游边界，提供认证、完整性、机密性和拓扑隐藏。

答题要点

- 2G/3G/4G 漫游中 SS7/Diameter 存在历史信任问题；
- 攻击者可能通过信令网查询位置、截获短信、发起欺骗请求；
- 5G 引入 SEPP 保护 PLMN 之间的信令边界；
- SEPP 提供运营商之间的认证、完整性、机密性和拓扑隐藏；
- 但 SEPP 保护的是运营商互联边界，不是 UE 与基站之间的空口；
- 仍需要 5G-AKA、NAS/AS 安全、SUPI/SUCI 等机制配合。

十、最后一道最可能的“综合题套路”

如果把所有预测压缩成一个最可能的出题类型，我认为是：

给一个简化无线通信安全方案，例如“终端与基站共享密钥，用某种加密模式保护数据，用 IV/计数器/随机数作为输入，没有或弱完整性保护，切换/重连时复用密钥”，要求分析安全缺陷并提出改进。

对这个综合题套路的参考答案

这类题基本是把密码模式、完整性、防重放、密钥管理和移动通信切换揉在一起考。可以按下面写。

1. 不能只看使用了强加密算法

- 即使使用 AES，也不代表方案安全。
- 还要看 IV/nonce/counter 是否唯一，是否有完整性保护，是否有防重放，密钥是否分离和更新。

2. IV/计数器/随机数问题

- 如果 IV 固定、计数器重启归零、随机数太短，可能导致同一密钥下输入重复。
- 对 CTR/OFB/GCM/CCM 这类模式，会导致密钥流重复。
- 攻击者可通过两个密文异或得到明文关系。

3. 完整性问题

- 如果没有 MAC、HMAC、CMAC 或 AEAD tag，则只提供保密性，不提供防篡改。
- 攻击者可以修改、插入、删除密文，接收方无法可靠发现。
- 如果用 CRC 代替 MAC，也不安全，因为 CRC 无密钥且线性。

4. 重放问题

- 如果没有序列号、时间戳、随机挑战或滑动窗口，攻击者可以重放旧消息。
- 控制信令被重放尤其危险，如接入、断开、切换、授权命令。

5. 密钥管理问题

- 长期使用同一共享密钥会扩大泄露影响。
- 上行/下行、信令/用户面、加密/完整性共用密钥会破坏密钥分离。

- 切换或重连时复用旧密钥，会导致旧节点可能知道未来通信密钥，后向安全差。

6. 改进方案

- 使用 AEAD，例如 AES-GCM 或 AES-CCM。
- 保证 nonce 全局唯一，计数器掉电不回滚。
- 在 nonce 或算法输入中加入 COUNT、BEARER、DIRECTION、设备 ID、会话号。
- 加入序列号和滑动窗口防重放。
- 用 KDF 派生上行/下行、信令/用户面、加密/完整性不同密钥。
- 切换时使用新密钥，参考 LTE/5G 的 NH/NCC 或核心网参与派生。
- 定期重协商密钥，必要时使用 Diffie-Hellman 增强前向安全。

一句话版：

该方案的问题通常集中在 IV/nonce 重复、只加密不认证、缺少防重放、密钥长期复用和切换时密钥隔离不足。改进方向是 AEAD、nonce 唯一、防重放、KDF 密钥分离、上下行/信令/用户面分离以及切换时更新密钥。

这类题可以同时考：

- 密码模式；
- IV/nonce；
- 重放攻击；
- 完整性保护；
- 密钥管理；
- 上下行方向隔离；
- 无线链路攻击；
- LTE/5G 的 COUNT / BEARER / DIRECTION 思想；
- 方案改进能力。

十一、最后分析题通用答题模板

无论它考 AES、LTE、5G、WLAN、TETRA，都可以按这个模板写。

第一步：说明安全目标

先写：

- 机密性；
- 完整性；
- 身份认证；

- 防重放 / 新鲜性；
- 密钥管理；
- 身份隐私；
- 访问控制；
- 可用性；
- 前向安全 / 后向安全。

第二步：找攻击者能力

可以写：

- 攻击者能窃听无线信道；
- 攻击者能重放旧消息；
- 攻击者能篡改、插入、删除消息；
- 攻击者可能伪装基站或终端；
- 攻击者可能获得部分旧密钥；
- 攻击者可能控制中间网络节点；
- 攻击者可能利用切换、漫游、降级过程。

第三步：逐项分析方案问题

常见得分点：

- 只加密不认证；
- IV/nonce 重复；
- IV 可预测或没有认证；
- 没有序列号；
- 没有防重放窗口；
- 密钥长期不更新；
- 上下行共用密钥；
- 信令 and 用户面共用密钥；
- 没有双向认证；
- 永久身份明文暴露；
- 切换时复用旧密钥；
- 漫游边界过度信任；
- 没有降级防护；
- 没有密钥确认。

第四步：提出改进

可以写：

- 使用 AEAD，例如 AES-GCM / AES-CCM；
- 保证 nonce 全局唯一；
- 加入 COUNT / BEARER / DIRECTION / 序列号；
- 使用 MAC / HMAC / CMAC / GMAC；
- 引入挑战-响应或时间戳防重放；
- KDF 派生不同用途密钥；
- 加密密钥和完整性密钥分离；
- 上下行密钥分离；
- NAS / AS / RRC / UP 密钥分离；
- 切换时使用新密钥或 NH/NCC；
- 使用临时身份或 SUCI 保护用户身份；
- 漫游用 SEPP；
- 企业 WLAN 用 802.1X/EAP/RADIUS；
- 应用层用 TLS/HTTPS；
- 加入审计、吊销、密钥更新和异常检测。

第五步：总结取舍

最后补一句：

改进方案会增加计算、带宽、时延和管理复杂度，但能显著提升机密性、完整性、抗重放、身份隐私和密钥泄露后的隔离能力。

十二、最建议最后重点背的三套答案

如果时间有限，优先背这三套。

1. “密码模式分析题”模板

关键词：

IV/nonce 唯一、密钥流不能重复、只加密不完整、AEAD、防重放、KDF、密钥分离、密钥更新。

2. “LTE/5G 密钥体系分析题”模板

关键词：

K_ASME / K_SEAF / K_AMF, NAS/AS 分层, K_eNB / K_gNB, RRC/UP 分离, NH/NCC, 横向派生快但前向安全弱, 纵向派生安全但开销高。

3. “WLAN/WEPA/WPA 分析题”模板

关键词：

WEPA 的 24-bit IV、RC4、CRC32、静态共享密钥、密钥流复用、比特翻转、字典攻击；
WPA2 用 802.1X/PSK + 四次握手 + CCMP；WPA3 用 SAE/GCMP 增强。

十三、最终押题判断

如果只能押一个方向：

今年最后一道分析题大概率会给一个“使用某种加密模式或密钥管理方式保护无线通信”的具体方案，让你分析它在机密性、完整性、防重放、密钥更新、身份认证方面的问题，并提出改进。

最可能出现的关键词是：

- AES-CTR / AES-GCM / AES-CCM；
- IV / nonce / COUNT；
- 上行下行共用密钥；
- 只加密不完整性保护；
- 重放攻击；
- 密钥长期不更新；
- 切换时复用密钥；
- LTE/5G 的密钥分层思想；
- AEAD；
- KDF；
- NAS/AS 或 RRC/UP 分离。

复习时不要只背“某协议是什么”，而要练：

看到一个方案后，能马上回答：它保护了什么？没保护什么？攻击者怎么打？应该怎么改？为什么这样改？

附录一：不会分析时怎么拆题

先记住一句话：

分析题不是让你凭空发明攻击，而是让你把题干里的设计逐项对照安全目标：它有没有认证？有没有加密？有没有完整性？有没有防重放？密钥有没有分离？计数器会不会重复？身份会不会暴露？切换或漫游时旧节点能不能知道新密钥？

答题时可以按下面这个顺序扫题干：

1. 看到“加密算法很强”，不要马上认为安全

很多题会故意说：

- 使用 AES；
- 使用 KASUMI；
- 使用 ZUC；
- 使用公钥加密；
- 使用共享密钥 K；
- 使用安全信道预先分发密钥。

这只能说明“算法可能强”，不能说明“协议安全”。

继续问：

1. IV / nonce / 计数器是否唯一？
2. 是否有 MAC / 完整性校验 / AEAD tag？
3. 是否有序列号、时间戳、随机挑战防重放？
4. 上行和下行是否区分？
5. 信令和用户面是否区分？
6. 密钥是否长期不变？
7. 切换、重连、掉电后状态是否会回滚？
8. 身份是否明文发送？
9. 是否只有单向认证，没有双向认证？
10. 旧节点被攻破后，能不能推导新节点密钥？

如果其中任何一项答案不好，就可以展开写安全问题。

附录二：各种加密模式到底怎么分析

这是最容易混的地方。考试里如果把 AES-CBC 换成 AES-CTR、AES-GCM、AES-CCM、OFB、CFB，不是让你背复杂公式，而是看你能不能说：

- 这个模式靠什么保证机密性；

- IV / nonce / counter 的要求是什么；
- 重复会导致什么；
- 是否自带完整性保护；
- 攻击者改密文会发生什么。

1. ECB：看到就直接判不安全

关键词：

- 没有 IV；
- 相同明文块加密后得到相同密文块；
- 会泄露明文模式。

怎么分析：

ECB 把每个分组独立加密，相同明文块会得到相同密文块，因此不能隐藏数据结构和重复模式。它不提供完整性保护，攻击者还可以剪切、替换、重排密文块。无线通信中数据包格式往往有固定头部和重复字段，因此 ECB 不适合保护通信数据。

改进：

- 不使用 ECB；
- 改用 CBC + 随机 IV + MAC；
- 或直接使用 AEAD，例如 GCM / CCM。

2. CBC：重点看 IV、填充、完整性

CBC 加密大致是：

$$C_i = E_K(P_i \oplus C_{i-1})$$

第一个分组用 IV 代替前一个密文块。

看到 CBC 时，重点看三件事：

(1) IV 是否随机、不可预测、每次不同

如果 IV 固定或重复：

- 相同明文开头可能产生相同密文开头；
- 会泄露消息是否有相同前缀；
- 在某些可选择明文场景下，攻击者可以构造输入来验证明文猜测。

答题写法：

CBC 模式要求每次加密使用新的、不可预测的 IV。如果 IV 固定、重复或可预测，则相同明文前缀可能产生可识别的密文模式，攻击者可以判断不同消息是否具有相同开头，甚至在选择明文条件下进行猜测攻击。

(2) CBC 不自带完整性

即使 IV 正确，CBC 也只解决机密性，不解决篡改。

攻击者改某个密文块，会影响解密后的对应块和下一块。尤其可以通过修改前一块密文来影响后一块明文的某些比特。

答题写法：

CBC 加密不等于完整性保护。攻击者虽然未必能读懂明文，但可以修改密文，使解密后的明文发生可控或半可控变化。如果系统没有 MAC 或 AEAD tag，接收方无法可靠发现篡改。

(3) 小心 padding oracle

如果题干出现：

- 填充错误；
- 解密失败原因会返回给攻击者；
- 错误码不同；
- 先解密再验证；

就写 padding oracle。

答题写法：

如果系统在 CBC 解密时对填充错误和 MAC 错误返回不同提示，攻击者可以利用 padding oracle 逐步恢复明文。因此应先验证完整性再解密，或者使用 AEAD 模式。

CBC 改进：

- IV 必须随机、不可预测、每次不同；
- IV 可明文传输，但要被完整性保护覆盖；
- 加 MAC，最好 Encrypt-then-MAC；
- 更推荐用 AES-GCM / AES-CCM。

3. CTR：重点看 nonce/counter 绝对不能重复

CTR 本质上是把分组密码变成流密码：

$$S_i = E_K(\text{nonce} || \text{counter}_i)$$

$$C_i = P_i \oplus S_i$$

所以 CTR 的核心不是“IV 要随机”，而是：

同一密钥 K 下，nonce/counter 组合绝对不能重复。

如果重复：

$$C_1 = P_1 \oplus S$$

$$C_2 = P_2 \oplus S$$

所以：

$$C_1 \oplus C_2 = P_1 \oplus P_2$$

这叫密钥流复用。

答题写法：

CTR 模式的安全性依赖于同一密钥下每个 nonce/counter 输入唯一。如果系统重启后计数器从 0 开始，或上下行使用相同密钥和相同计数器，则会重复生成同一段密钥流。攻击者将两个密文异或即可得到两个明文的异或关系；若知道其中一个明文，还能恢复另一个明文。

CTR 还要写：

- CTR 不自带完整性；
- 攻击者翻转密文某一位，会导致明文对应位翻转；
- 因此很容易被比特翻转攻击。

例子：

如果：

$$C = P \oplus S$$

攻击者把密文改成：

$$C' = C \oplus \Delta$$

解密得到：

$$P' = C' \oplus S = P \oplus \Delta$$

也就是说，攻击者改密文哪一位，明文对应位也会变。

CTR 改进：

- nonce/counter 持久化，掉电不能回滚；
- 上行、下行加入方向标识；
- 不同承载加入 bearer 标识；
- 加 MAC / HMAC / CMAC；
- 或直接使用 GCM / CCM。

4. OFB：和 CTR 一样按“流密码”分析

OFB 也是生成密钥流再和明文异或。

所以考试中看到 OFB，可以基本套 CTR 的思路：

- IV / 初始状态不能重复；
- 重复会导致密钥流重复；
- 密文异或泄露明文异或；
- 不自带完整性；
- 可被比特翻转。

答题写法：

OFB 模式本质上也是同步流密码。若同一密钥下 IV 重复，则会生成相同密钥流，导致两个密文异或等于两个明文异或。OFB 只提供机密性，不提供完整性保护，因此还需要 MAC 或 AEAD。

5. CFB：也要关注 IV，但错误传播和 CTR/OFB 略不同

CFB 也是把分组密码变成类似流密码的模式。

常见分析点：

- IV 不能重复，最好不可预测；
- 不自带完整性；
- 密文被改会影响解密结果；
- 有一定错误传播，但不能当作完整性保护。

答题写法：

CFB 模式虽然密文错误会传播到后续若干分组，但这不是密码学完整性保护。攻击者仍可通过篡改密文干扰明文或协议状态，接收方无法可靠判断是否遭到恶意修改，因此仍需 MAC 或 AEAD tag。

6. GCM：重点看 nonce 唯一 + 自带认证

GCM = CTR 加密 + GHASH 认证。

它是 AEAD，既提供：

- 机密性；
- 完整性；
- 认证标签 tag；
- 还能保护附加认证数据 AAD，例如包头、序列号、方向字段。

但 GCM 有一个巨大要求：

同一密钥下 nonce 绝对不能重复。

如果 nonce 重复：

- CTR 部分会重复密钥流，破坏机密性；
- GHASH 认证也可能被攻击，导致伪造 tag；
- 比普通 CTR 更严重。

答题写法：

AES-GCM 是 AEAD 模式，正常使用时能同时提供加密和完整性保护。但它强烈依赖 nonce 唯一性。如果设备掉电后计数器回滚，或者多个方向/承载复用同一 nonce 空间，就可能在同一密钥下重复 nonce。nonce 重复会导致密钥流复用，破坏机密性，并可能进一步破坏认证标签的安全性。

GCM 改进：

- 使用全局唯一 nonce；
- nonce 中加入设备 ID、方向、承载、序列号；
- 计数器掉电不回滚；
- 快到上限时必须换密钥；
- tag 验证失败必须丢弃消息。

7. CCM: CTR 加密 + CBC-MAC 认证

CCM 也属于 AEAD，常见于 WPA2-CCMP。

它的核心：

- CTR 负责加密；
- CBC-MAC 负责完整性；

- nonce 也必须唯一。

答题写法：

AES-CCM 同时提供机密性和完整性，适合无线链路保护，例如 WPA2-CCMP。但 CCM 仍要求同一密钥下 nonce 不重复。如果重放计数器或包号重复，会导致 CTR 密钥流复用，并破坏整体安全。因此需要严格的包号、重放计数器和密钥更新机制。

8. GCM 和 CCM 怎么区分答？

考试一般不要求你推公式，只要会说：

模式	本质	是否自带完整性	最怕什么	常见场景
CBC	分组链式加密	否	IV 固定/可预测、padding oracle、无 MAC	传统分组加密
CTR	计数器流密码	否	nonce/counter 重复、比特翻转	高速加密、LTE AES-CTR 思想
OFB	同步流密码	否	IV 重复导致密钥流重复	流式传输
CFB	反馈流式模式	否	IV 问题、无完整性	流式传输
GCM	CTR + GHASH	是	nonce 重复	现代 AEAD、WPA3-GCMP
CCM	CTR + CBC-MAC	是	nonce 重复	WPA2-CCMP

最简判断：

- CBC：先看 IV 随机不可预测，再看 MAC，再看 padding oracle。
- CTR/OFB/流密码：先看 nonce/IV 是否重复，再看是否有 MAC。
- GCM/CCM：先看 nonce 是否唯一，再看 tag 是否验证，再看是否防重放。
- 任何模式：只加密不认证，都要写完整性不足。

附录三：IV、nonce、counter 到底怎么看

很多题不是直接说“IV 重复”，而是藏在描述里。

1. 看到这些话，就要怀疑重复

- 系统重启后 COUNT 从 0 开始；
- 设备掉电后计数器可能回滚；
- 多个设备使用相同初始计数器；

- 上行和下行使用同一个计数器；
- 不同承载共用同一计数器；
- IV 由时间戳低位生成；
- IV 只有 24 bit；
- 随机数长度太短；
- 长期使用同一个密钥，但没有说明计数器如何持久化；
- nonce 由设备编号和本地计数器组成，但本地计数器可能恢复出厂或回滚。

看到这些，就写：

同一密钥下可能出现 IV/nonce/counter 重复，导致密钥流复用或相同明文模式泄露。

2. IV 是否可以公开？

可以。

但是：

- IV 可以公开，不等于可以重复；
- IV 可以公开，不等于可以被攻击者随意篡改；
- 对 CBC，IV 最好不可预测；
- 对 CTR/GCM/CCM，nonce 重点是唯一；
- IV/nonce 最好纳入 MAC 或 AEAD 的认证范围。

答题写法：

IV/nonce 本身不一定需要保密，可以随密文发送；但它必须满足模式要求，并应受到完整性保护。攻击者如果能篡改 IV/nonce，可能影响解密结果或导致接收方状态混乱。

3. “随机 IV”和“计数器 nonce”哪个好？

考试中不要绝对化。

- CBC 常说随机、不可预测 IV；
- CTR/GCM/CCM 更强调唯一 nonce，可以用递增计数器；
- 无线通信常用 COUNT / BEARER / DIRECTION 组合，目的就是避免重复。

附录四：完整性问题到底怎么看

1. 什么叫“只加密不认证”

题干如果只写：

- 使用 AES 加密；
- 使用 RC4 加密；
- 使用 KASUMI 加密；
- 使用 ZUC 加密；
- 使用 CTR/OFB/CBC 加密；

但没有写：

- MAC；
- HMAC；
- CMAC；
- CBC-MAC；
- GMAC；
- MIC；
- AEAD tag；
- 完整性保护算法；
- EIA / f9；
- NAS-MAC / MAC-I；

那就按“只加密不认证”分析。

2. 为什么只加密不够？

因为加密只回答：

攻击者能不能看懂？

完整性回答：

攻击者能不能改？接收方能不能发现被改？

很多加密模式下，攻击者虽然看不懂，但仍然可以改。

答题写法：

该方案只提供机密性，不提供完整性。攻击者虽然不能直接恢复明文，但可以修改、插入、删除或重放密文，使接收方解密出错误数据或执行错误控制命令。

3. CRC 为什么不算完整性保护？

CRC 是检错码，用来发现自然传输错误，不是防恶意攻击。

因为：

- CRC 没有密钥；
- 攻击者修改数据后可以重新计算 CRC；
- CRC 线性，甚至可以配合比特翻转构造合法校验值。

答题写法：

CRC32 只能检测随机传输错误，不能抵抗恶意篡改。由于 CRC 没有密钥且具有线性结构，攻击者可以在修改数据后同步修改 CRC，使接收方误以为数据合法。因此 CRC 不能替代 MAC。

4. MAC 和数字签名有什么区别？

考试中简单写：

- MAC/HMAC/CMAC：双方共享密钥，效率高，用于完整性和认证；
- 数字签名：私钥签名、公钥验证，可提供不可否认性，但开销大；
- 无线链路通常用 MAC/AEAD；
- 需要不可否认性、证据保全时才考虑数字签名。

附录五：重放问题到底怎么看

1. 什么是重放？

攻击者不需要破解密文，只要把旧消息重新发一遍。

比如：

- 旧的接入请求；
- 旧的认证响应；
- 旧的开门命令；
- 旧的切换命令；
- 旧的断开连接命令；
- 旧的授权消息。

如果接收方无法判断“这是不是旧消息”，就有重放风险。

2. 看到什么就判断有重放风险？

题干没有出现以下内容时，就写重放风险：

- 序列号;
- 时间戳;
- 随机挑战 nonce;
- 计数器;
- 滑动窗口;
- freshness;
- SQN;
- COUNT;
- replay counter。

答题写法:

方案中没有体现新鲜性机制。攻击者可以记录一次合法通信, 之后原样重放。由于接收方没有序列号、时间戳、随机挑战或滑动窗口, 无法判断消息是否为旧消息。

3. 加密能防重放吗?

不能。

旧密文虽然看不懂, 但仍然是合法密文。接收方可能照样解密和执行。

答题写法:

加密只能隐藏内容, 不能证明消息是新鲜的。旧密文仍然可能通过解密验证, 因此必须引入序列号、时间戳、随机挑战或重放窗口。

4. 防重放机制怎么写?

- 认证协议: 随机挑战 nonce;
- 数据包传输: 递增序列号 + 滑动窗口;
- 移动通信: SQN / COUNT;
- WLAN: 重放计数器;
- 时间敏感系统: 时间戳, 但要考虑时钟同步和窗口。

附录六: 前向安全、后向安全到底怎么判断

这部分你最容易卡住, 可以用“站在攻击者拿到旧密钥或新密钥之后, 往前看、往后看”的方法。

1. 先把两个概念说成人话

前向安全 Forward Security

问的是：

现在某个节点或当前密钥泄露了，攻击者能不能解密过去的通信？

如果不能解密过去，说明有前向安全。

关键词是：

- 当前泄露；
- 保护过去。

后向安全 Backward Security

问的是：

旧节点或旧密钥泄露了，攻击者能不能知道未来的新通信？

如果不能知道未来，说明有后向安全。

关键词是：

- 旧的泄露；
- 保护未来。

2. 用一句口诀记

前向安全：现在出事，不连累过去。

后向安全：过去出事，不连累未来。

或者：

前向看过去，后向看未来。

3. 怎么判断有没有前向安全？

看新密钥能不能推出旧密钥。

如果密钥链是这样：

$$K_1 \rightarrow K_2 \rightarrow K_3$$

并且：

$$K_2 = f(K_1)$$

$$\overset{\text{分析题}}{K_3 = f(K_2)}$$

如果 f 是单向函数，知道 K_3 通常不能反推 K_2 、 K_1 ，所以对过去有一定保护。

但如果系统长期用同一个 K ：

$$K_1 = K_2 = K_3 = K$$

那么现在 K 泄露，过去所有用 K 加密的数据都能被解密，没有前向安全。

答题写法：

如果长期复用同一通信密钥，则当前密钥泄露会导致历史通信也被解密，因此不具备前向安全。若每次会话通过新的随机数或 Diffie-Hellman 派生独立会话密钥，并且旧密钥及时删除，则当前密钥泄露不应影响过去会话，前向安全更好。

4. 怎么判断有没有后向安全？

看旧密钥能不能推出新密钥。

如果新密钥只是从旧密钥直接算出来：

$$K_{new} = KDF(K_{old}, \text{参数})$$

而攻击者知道 K_{old} 和公开参数，那么他也能算 K_{new} 。

这就没有后向安全。

如果新密钥引入了攻击者不知道的新随机量、核心网密钥或 DH 新秘密：

$$K_{new} = KDF(K_{old}, \text{新随机数, 核心网秘密})$$

或者由核心网重新下发攻击者不知道的 NH，那么旧密钥就不能推出新密钥，后向安全更好。

答题写法：

如果目标基站的新密钥由旧基站持有的密钥直接派生或直接转交，则旧基站一旦被攻破，攻击者可以得到未来目标基站使用的密钥，后向安全不足。若新密钥由核心网参与派生，或使用 NH/NCC 等机制切断旧基站与新基站密钥关系，则后向安全更强。

5. LTE 切换里怎么判断？

情况 A：旧 eNodeB 直接把 K_{eNB} 发给新 eNodeB

结论：很差。

原因：

- 旧基站知道新基站密钥；
- 旧基站被攻破会影响未来通信；
- 后向安全差；
- 目标基站和源基站没有密钥隔离。

答题写法：

源 eNodeB 直接向目标 eNodeB 发送密钥会导致目标小区通信密钥暴露给源 eNodeB。一旦源 eNodeB 被攻破，攻击者可以继续解密切换后的通信，因此缺乏后向安全和密钥隔离。

情况 B：横向派生

例如：

$$K_{eNB}^* = KDF(K_{eNB}, PCI, EARFCN)$$

特点：

- 快；
- 不需要核心网实时参与；
- 适合低时延切换；
- 但源 eNodeB 如果知道当前 K_{eNB} 和参数，可能推导目标 K_{eNB}^* ；
- 所以后向安全较弱。

答题写法：

横向派生可以降低切换时延，但由于新密钥与源基站当前密钥存在直接派生关系，若源基站被攻破，攻击者可能推导目标基站密钥，因此后向安全较弱。

情况 C：纵向派生 / NH/NCC

特点：

- NH 由 MME/核心网侧参与生成；
- 目标基站使用 NH 派生新密钥；
- 源基站不知道 NH 或不能推出后续 NH；
- 能切断源基站和目标基站的密钥关系；
- 后向安全更强，但可能增加信令和时延。

答题写法：

纵向派生利用核心网提供的 NH 派生目标基站密钥，使源 eNodeB 不能根据自己持有的旧 K_{eNB} 推导目标 eNodeB 的新密钥，从而增强后向安全。代价是需要核心网或预先的 NH 链支持，切换复杂度和时延可能增加。

6. 什么时候说“没有前向安全”？

看到这些情况就写：

- 长期使用同一个密钥；
- 会话密钥由长期密钥直接加密传输；
- 没有 DH 或新随机性；
- 当前密钥泄露后可以解密以前录下的密文；
- 旧密钥没有删除。

7. 什么时候说“没有后向安全”？

看到这些情况就写：

- 新密钥由旧密钥直接派生；
- 旧基站把密钥直接交给新基站；
- 成员退出群组后不更新组密钥；
- 设备被撤销后仍能计算未来密钥；
- 切换后继续沿用原来的密钥。

8. 群组通信里的前向/后向安全

TETRA、组播、群组通信也可以这样判断：

- 新成员加入后，不能解密加入前的历史消息：这是前向安全；
- 老成员退出后，不能解密退出后的未来消息：这是后向安全。

所以群组通信中：

- 有成员加入，要更新组密钥，防止他看过去；
- 有成员退出，也要更新组密钥，防止他看未来。

附录七：密钥分离到底怎么分析

1. 看到“所有业务共用一个密钥”，直接写问题

例如题干说：

- 上行和下行使用同一密钥；
- NAS、RRC、UP 使用同一密钥；
- 加密和完整性使用同一密钥；
- 所有用户共享同一个 PSK；
- 所有设备出厂内置同一个密钥；
- 信令和用户数据共用密钥。

都要写密钥分离不足。

2. 为什么要分离？

因为不同用途的密钥风险不同。

如果共用一个密钥：

- 一个场景泄露，所有场景都泄露；
- 一个方向的攻击可能影响另一个方向；
- 加密算法和完整性算法之间可能相互影响；
- 无法单独撤销、更新、限制权限；
- 不利于定位和隔离攻击。

答题写法：

该方案缺少密钥分离。上行、下行、信令、用户面、加密和完整性保护使用同一密钥，会扩大单个密钥泄露的影响范围，也可能导致跨方向、跨业务的重放或密钥流复用风险。应使用 KDF 从主密钥派生不同用途的子密钥。

3. LTE/5G 里怎么套

可以写：

- NASenc / NASint 分离；
- RRCenc / RRCint 分离；
- UPenc / UPint 分离；
- K_eNB / K_gNB 不应等于核心网主密钥；
- 上行 / 下行通过 DIRECTION 区分；
- 不同 bearer 通过 BEARER 区分；
- 不同包通过 COUNT 区分。

4. WLAN 里怎么套

可以写：

- PMK 不直接加密数据；
- 四次握手用 ANonce、SNonce、双方 MAC 派生 PTK；
- PTK 再分成 KCK、KEK、TK；
- KCK 保护握手完整性；
- KEK 加密 GTK；
- TK 加密数据；
- 这样不同用途互相隔离。

附录八：身份隐私题怎么分析

1. 看到永久身份明文发送，就写隐私泄露

关键词：

- IMSI 明文；
- SUPI 明文；
- 固定设备 ID；
- 固定 MAC 地址；
- 长期不变的用户标识；
- 每次接入都发送同一个身份。

问题：

- 攻击者可以识别用户；
- 可以长期跟踪位置；
- 可以做 IMSI Catcher / 伪基站诱骗；
- 可以关联用户行为。

答题写法：

如果终端在空口明文发送永久身份，攻击者只需被动监听即可识别用户，并可在不同时间地点关联同一用户的活动轨迹，造成身份隐私和位置隐私泄露。

2. TMSI/GUTI/SUCI 分别解决什么

- TMSI：临时身份，减少 IMSI 暴露，但不是加密 IMSI；
- GUTI/S-TMSI：LTE 临时身份，继续减少永久身份暴露；
- SUCI：5G 用归属网络公钥隐藏 SUPI，防止空口明文暴露永久身份。

3. 临时身份不等于完全匿名

因为：

- 初次接入可能仍暴露永久身份；
- 临时身份失效时可能回退；
- 伪基站可能诱导发送永久身份；
- 流量模式、位置、时间仍可能关联用户；
- 降级到 2G/3G/4G 可能破坏 5G 隐私保护。

答题写法：

临时身份或 SUCI 只能降低永久身份在空口暴露的概率，不等于完全匿名。攻击者仍可能通过降级攻击、伪基站诱导、流量分析和位置关联进行跟踪。因此还需要双向认证、拒绝降级、NAS/AS 安全和策略控制。

附录九：WLAN 题怎么从题干抓漏洞

1. 看到 WEP，直接抓五个点

- RC4；
- 24 bit IV 太短；
- IV 重复导致密钥流复用；
- CRC32 不是 MAC；
- 静态共享密钥，难更新难撤销。

答题模板：

该方案本质上类似 WEP。WEP 使用 RC4 流密码，IV 只有 24 bit，在高流量环境下很容易重复，导致相同密钥流被复用。CRC32 只能检错不能防篡改，攻击者可以进行比特翻转并调整 CRC。共享静态密钥也导致一人泄露影响全网，且难以撤销单个用户。因此应升级到 WPA2/WPA3，使用 802.1X/EAP/RADIUS 或 SAE，并使用 CCMP/GCMP 提供加密和完整性保护。

2. 看到 WPA2-PSK 全员共享密码

问题：

- 所有人知道同一个口令；
- 离职或泄露后难以撤销单人；
- 弱口令可能被离线字典攻击；
- 同一网络内用户之间隔离弱；

- 企业场景不适合共享 PSK。

改进：

- WPA2-Enterprise / WPA3-Enterprise；
- 802.1X + EAP + RADIUS；
- 每用户账号或证书；
- 强口令和定期更新；
- 访客网络隔离。

3. 看到四次握手

重点看：

- ANonce / SNonce 是否随机且不重复；
- PTK 是否由 PMK、双方 nonce、双方 MAC 派生；
- EAPOL-Key 消息有没有 MIC；
- 重放计数器有没有检查；
- 是否可能密钥重装。

答题写法：

四次握手不仅是交换随机数，还要完成密钥确认、完整性保护和重放防护。如果没有正确检查重放计数器，攻击者可以重放握手消息，诱导终端重新安装已经使用过的密钥，从而导致 nonce/packet number 重用，引发密钥重装类攻击。

附录十：TETRA 题怎么分析

1. 先判断保护范围

TETRA 题最重要的是分清三层：

机制	保护范围	不能保护什么
空口加密	终端 MS 到基站/SwMI 空口	核心网、调度台、中间节点可能看明文
传输加密	基站到交换/核心网链路	处理节点内部可能看明文
端到端加密	终端到终端业务内容	调度、合法监听、群组管理会复杂

看到题干说“只做空口加密”，就写：

只能防无线窃听，不能防网络内部节点或调度系统看到明文。

看到题干说“端到端加密”，就写：

业务内容保护更强，但群组密钥、迟到加入、成员撤销、同步、合法监听和调度管理更复杂。

2. 群组通信一定要想到密钥管理

群组通信不是两个人聊天。

要考虑：

- 谁是组成员；
- 新成员加入能不能看历史消息；
- 旧成员退出能不能看未来消息；
- 调度台是否有权监听；
- 合法监听如何实现；
- 迟到加入如何同步密钥流；
- 组密钥泄露影响整个组。

3. 端到端加密为什么还需要同步？

因为很多语音加密本质上用密钥流。发送端和接收端必须在同一个密钥流位置，否则解密会乱码。

答题写法：

端到端加密需要发送端和接收端保持密钥流或帧计数同步。若群组成员迟到加入、丢包或切换信道，接收端可能不知道当前密钥流状态，导致无法正确解密。因此需要同步向量、帧号、重新同步机制或周期性同步信息。

附录十一：5G/SUPI/SUCI/SEPP/SBA 题怎么分析

1. SUPI/SUCI 题

看到“SUPI 明文”：写身份隐私泄露。

看到“SUCI”：写它保护永久身份，但不是万能匿名。

答题结构：

1. SUPI 是永久身份，明文发送会被 IMSI Catcher 类攻击利用；
2. SUCI 用归属网络公钥隐藏 SUPI，降低空口永久身份暴露；

3. 但 SUCI 不防所有跟踪，因为位置、时间、流量模式、临时身份仍可能关联；
4. 如果允许降级到 2G/3G/4G，仍可能暴露 IMSI；
5. 还需要双向认证、拒绝降级、NAS/AS 安全和策略控制。

2. 5G-AKA 题

不要只写“认证成功就安全”。要写：

- 5G-AKA 完成 UE 与网络认证；
- 产生 K_SEAF / K_AMF 等后续密钥材料；
- 后续还要执行 NAS Security Mode Command；
- 再建立 AS/RRC/UP 安全；
- AKA 不等于所有数据自动加密完整性保护。

答题写法：

5G-AKA 主要解决接入认证和密钥材料生成问题，它本身不是后续所有业务数据的完整保护机制。认证完成后仍需通过 NAS 安全模式命令启用 NAS 加密和完整性保护，并进一步派生 AS/RRC/UP 密钥保护无线接入层和用户面。

3. SEPP 题

看到“漫游”“运营商之间”“PLMN 之间”“拜访网络”“归属网络”，就想到 SEPP。

答题写法：

SEPP 保护的是运营商与运营商之间的漫游信令边界，而不是 UE 到 gNB 的空口。它用于解决 2G/3G/4G 中 SS7/Diameter 过度信任带来的信令伪造、位置查询、隐私泄露等问题，提供跨 PLMN 的认证、完整性、机密性和拓扑隐藏。

4. SBA 题

看到“服务化架构”“API”“网络功能 NF”“注册发现”，就写：

- API 暴露面扩大；
- NF 必须认证；
- 服务调用要授权；
- 使用 TLS；
- 服务注册发现要保护；
- 日志审计和最小权限；
- 防止伪造 NF 或越权调用。

附录十二：分析题万能“定位问题”表

考试时可以在脑子里按这个表扫一遍：

题干细节	你应该想到的问题	答题关键词
只说加密，没说 MAC	只保密不完整	篡改、插入、删除、比特翻转
使用 CRC32 校验	CRC 不是 MAC	线性、无密钥、可伪造
IV 固定或重复	模式安全破坏	CBC 泄露前缀；CTR/OFB/GCM 密钥流复用
计数器重启归零	nonce/counter 重复	掉电回滚、密钥流重复
上下行同密钥同计数器	跨方向密钥流重复	DIRECTION、密钥分离
不同承载共用计数器	跨 bearer 重复	BEARER、COUNT
没有序列号/时间戳/nonce	重放	新鲜性、滑动窗口
长期同一个密钥	泄露影响大	密钥更新、前向安全差
旧基站把密钥给新基站	切换密钥隔离差	后向安全差、NH/NCC
所有层共用密钥	密钥分离不足	NAS/AS/RRC/UP 分离
永久身份明文	身份隐私泄露	IMSI/SUPI、TMSI/GUTI/SUCI
只有网络认证用户	可能伪基站	双向认证
DH 没有签名或认证	中间人攻击	认证密钥交换
全员共享 Wi-Fi 密码	难撤销、易泄露	802.1X、EAP、RADIUS
群组成员退出不换密钥	退出者可看未来	后向安全、组密钥更新
新成员加入不换密钥	新成员可看历史	前向安全、组密钥更新
允许降级到旧系统	降级攻击	禁止弱算法、策略控制

附录十三：真正考试时的“笨办法答题流程”

如果你看到题完全懵，就按下面 6 句话写，每句话展开 2 到 3 点，基本不会空。

第 1 句：先评价总体

该方案不能只看使用了某某算法，还要看认证、完整性、防重放、密钥管理和身份隐私是否完整。

第 2 句：说机密性

如果 IV/nonce/counter 设计不当，可能导致相同密钥流或相同密文模式，进而泄露明文关系。

第 3 句：说完整性

如果没有 MAC/AEAD，攻击者可以篡改、插入或删除密文，接收方无法可靠发现。

第 4 句：说重放

如果没有序列号、时间戳、随机挑战或滑动窗口，攻击者可以重放旧消息。

第 5 句：说密钥

如果长期使用同一密钥，或者上行/下行、信令/用户面、加密/完整性共用密钥，会扩大密钥泄露影响，并可能导致跨场景攻击。

第 6 句：说改进

应使用 AEAD，保证 nonce 唯一，加入序列号和重放窗口，通过 KDF 派生不同用途密钥，并在切换、重连、成员变化时更新密钥。

这 6 句就是兜底答案。即使不会细节，也能拿到不少分。